

DESIGN PROPOSAL

Zenith Orbital Systems

Aerospace and Satellite Communications
Low Earth Orbit Data Relay and Autonomous Flight Telemetry

Design Proposal

For

Zenith Orbital Systems Ground Station

Dallas, Texas

Prepared By:

Noe Valencia

Principal Systems Security Engineer (PSSE)

May 10, 2026

CONFIDENTIAL | For Internal Use Only

BIO

Noe Valencia

Dallas, Texas | noe.valencia@zos-secure.com | (214) 555-0147

Professional Experience and Summary

I have been working on network and cybersecurity projects throughout this program and built a solid foundation in designing, assessing, and securing enterprise network environments. My focus has been on practical application, which is why this entire project was built around a real network topology rather than a hypothetical scenario. I used the actual ZOS Dallas ground station network as the starting point, ran a full CSET assessment against NIST CSF 2.0, identified the gaps, and designed the complete upgraded network to address every finding directly.

Everything in this proposal reflects real work completed throughout this engagement. The design decisions, the policies, the plans, and the budget are all tied to real findings and real operational requirements for Zenith Orbital Systems.

Network Systems Architecture

I have hands-on experience designing and analyzing unified network infrastructures. This includes working with firewall configurations, VLAN segmentation, structured cabling, and server environments. For this project I analyzed the existing ZOS Dallas office topology, ran the CSET assessment, identified all the gaps, and built out the upgraded design to address each finding. The goal was not to just recommend changes but to show exactly what those changes look like in a real deployable architecture.

Cybersecurity

My cybersecurity work in this program covered the full program lifecycle: CSET-based threat assessment, policy development across five domains, incident response planning with defined severity levels and IRT structure, risk management using structured scoring methodology, physical security design, and business continuity planning with ground-to-space link redundancy considerations specific to ZOS orbital operations.

Skills and Framework Knowledge

- NIST Cybersecurity Framework 2.0, all six functions: Govern, Identify, Protect, Detect, Respond, Recover
- CISA Cyber Security Evaluation Tool (CSET), assessment execution and gap analysis
- CIS Controls v8, Implementation Group 2 coverage
- CMMC Level 2, 110 practices from NIST SP 800-171

- Network design: Palo Alto NGFW, Cisco Catalyst switching, Meraki wireless, VLAN segmentation
- Endpoint protection: EDR/XDR platforms, Huntress MDR, Microsoft Defender E5
- Identity and Access Management: Okta, CyberArk PAM, Zero Trust architecture
- SIEM: Splunk Enterprise, deployment, ingestion design, and detection rule mapping
- Policy development using SANS Institute template methodology
- Business Continuity Planning: phased recovery procedures and alternate site operations

Contents

BIO 2

Executive Summary 11

Introduction 12

Document Objective 12

Unified Network System Design 12

Physical Topology 15

Wireless Access Point Topology 17

Physical and Cybersecurity 18

 Physical Security 18

Cybersecurity and AZTOF Framework 19

Risk Assessment 20

 CSET Before vs. After Comparison 20

 Risk Defense Distribution 21

Prioritized Action List, Top Five CSET Findings 22

 Three Priority Risks and Threats 22

Threat 1: Ransomware 22

Threat 2: Denial of Service Attack 24

Threat 3: Natural Disaster and Physical Disruption 26

CSET Cybersecurity Assessment 29

1. Purpose and Scope of This Narrative 29

2. Assessment Overview 29

 2.1 Assessment Tool and Standard 29

 2.2 Scope of Systems Assessed 30

 2.3 Assessment Methodology 30

3. Assessment 1: Original ZOS Network (February 20, 2026) 31

 3.1 Site Information 31

 Assessment Date 31

 February 20, 2026 31

 3.2 Original Network Configuration Summary 31

 3.3 Assessment 1 Findings: Security Assurance Level Analysis 32

 3.4 Assessment 1 Findings: Ranked Gap Analysis 32

 3.5 Assessment 1 Interpretation: What the Findings Mean for ZOS 33

4. Assessment 2: Redesigned ZOS Network (February 23, 2026) 34

4.1 Site Information.....	34
4.2 Redesigned Network Configuration Summary	34
4.3 Assessment 2 Findings: Gap Closure Analysis	35
5. Comparative Analysis: Before and After	36
5.1 NIST CSF 2.0 Function-by-Function Improvement	36
5.1.1 Govern (GV)	37
5.1.2 Identify (ID)	37
5.1.3 Protect (PR).....	37
5.1.4 Detect (DE).....	38
5.1.5 Respond (RS).....	38
5.1.6 Recover (RC).....	38
5.2 Overall Security Posture Improvement Summary	38
6. Assessment Limitations and Complementary Activities	39
7. Ongoing Recommendations and Next Steps	40
8. Conclusion	41
9. Sources and References.....	41
Finance and Pricing.....	43
1. Network Security Infrastructure.....	43
2. Endpoint Protection	43
3. Identity and Access Management.....	44
4. Cloud Infrastructure and Security	44
5. Physical Security	44
6. Compliance and Risk Management	45
7. Personnel and Training.....	45
8. Telecommunications and Connectivity	46
Professional Services and Implementation.....	46
Grand Total and Financing	47
Total Cost of Ownership Analysis.....	47
Cybersecurity Management Plan, AZTOF Framework.....	49
Framework Foundations	49
Six AZTOF Domains Applied to ZOS	49
Policies in Place	50
1. General Password Protection Policy.....	50
2. Server Vulnerability Management Policy	50

3. Network Device Management Policy	50
4. Application and Cloud Service Provider Management Policy	50
5. Cybersecurity Incident Response Plan	50
Business Continuity Plan Summary	52
BCP Recovery Team, Zenith Orbital Systems	52
Kevin D. Nguyen	52
Austin Relay Hub Operations Lead	52
Business Function Leader, Austin Failover	52
Recovery Phases	52
Incident Response Plan Summary	54
Incident Response Team	54
Severity Level Matrix	54
Conclusion	56
1. Purpose Password Protection Policy	57
2. Scope	57
3. Principle Statement	57
4. Senior Management Commitment	58
Chief Information Security Officer / Senior IT Leadership, Zenith Orbital Systems	58
5. Industry Benchmarks and Current Trends (2026)	58
5.1 Length Over Complexity	58
5.2 Elimination of Mandatory Periodic Rotation	58
5.4 MFA as the Primary Defense Layer	59
5.5 Password Managers as Organizational Infrastructure	59
6. Roles and Responsibilities	59
7. Policy Controls and Standards	59
7.1 Password Length and Format	59
7.2 Password Screening and Breach Detection	60
7.3 Password Expiration and Rotation	60
7.4 Multi-Factor Authentication (MFA)	61
7.5 Password Management Tools	61
7.6 Account Lockout	61
8. Legal and Regulatory Obligations	62
10. Compliance Measurement	63
11. Exception Management	63

12. Policy Sanctions	64
13. Sources and References	64
Server Vulnerability Management Policy	65
1. Purpose	65
2. Scope	65
3. Principle Statement	65
4. Senior Management Commitment	66
5. Roles and Responsibilities	66
6. Policy Safeguards	66
6.1 Vulnerability Management System and Scanning	66
6.2 Vulnerability Prioritization and Remediation SLAs	67
6.3 Exception Tracking and Reporting	68
7. Remediation SLA Summary	68
8. Penetration Testing	69
9. Legal and Regulatory Obligations	69
10. Training and Awareness	70
11. Compliance Measurement	70
12. Exception Management and Policy Sanctions	70
13. Continual Improvement	71
14. Sources and References	71
Network Device Management Policy	72
1. Purpose	72
2. Scope	72
3. Principle Statement	72
5. Roles and Responsibilities	73
6. Policy Safeguards	73
6.1 Inventory and Configuration Management	73
6.2 Secure Management Access	74
6.3 Monitoring and Logging	74
6.4 Firmware and Lifecycle Management	75
7. Legal and Regulatory Obligations	75
8. Continual Improvement and Sources	76
Cloud Service Provider Management Policy	77
1. Purpose	77

2. Scope	77
3. Principle Statement	77
4. Senior Management Commitment.....	78
5. CSP Onboarding Requirements	78
6. Ongoing CSP Monitoring Requirements	78
7. Data Classification and CSP Tier Assignment	79
8. CSP Offboarding Requirements	79
9. Legal and Regulatory Obligations	80
10. Sources and References	80
Cybersecurity Incident Response Plan.....	81
1. Goals for Cyber Incident Response.....	81
2. Purpose and Scope	81
3. Incident Response Team (IRT)	82
3.1 Primary IRT Members.....	82
3.2 Secondary IRT Members	83
4. Incident Response Lifecycle	83
5. Incident Occurrence and Awareness.....	84
6. Incident Response Process Detail	85
7. Communication Methods	87
8. Information Recording	88
10. Appendix A: IRT Incident Severity and Response Classification Matrix	89
11. Appendix B: IRT Member Contact List	90
12. Appendix C: IRT Incident Record Form.....	91
13. Sources and References	92
Cybersecurity Management Plan	93
1. Introduction	93
2. AZTOF Governance Framework	94
2.1 Framework Foundations	94
2.2 AZTOF Domain Descriptions	94
3. Fayol's Management Functions Applied to Each AZTOF Domain.....	95
3.1 Identity and Access Governance (IAG).....	95
3.2 Threat Detection and Incident Response (TDIR)	96
3.3 Data Protection and Privacy (DPP)	97
3.4 Vulnerability and Configuration Management (VCM)	97

3.5 Regulatory Compliance and Audit Readiness (RCAR).....	98
3.6 Security Culture and Workforce Resilience (SCWR).....	98
4. AZTOF Governance Summary Matrix.....	99
5. Conclusion	100
6. References and Sources.....	101
IT Department Business Continuity Plan.....	102
Section I: Introduction.....	102
A. How to Use This Plan	102
B. Objectives	102
C. Scope and Applicability.....	103
Section II: Business Continuity Strategy.....	103
A. Ground-to-Space Link Redundancy.....	103
B. Recovery Strategy Overview	103
C. Business Impact Analysis Summary.....	103
D. Recovery Phases.....	104
Section III: Recovery Teams	104
A. Purpose and Objective	104
B. Recovery Team Assignments	105
C. Personnel Notification	107
Section IV: Recovery Procedures	107
Phase I: Disaster Occurrence.....	107
Phase II: Plan Activation.....	107
Phase III: Alternate Site Operations.....	108
Phase IV: Return to Normal Operations	109
Section V: Appendices	109
Appendix A: ZOS Employee Telephone List.....	109
Appendix B: ZOS Alternate Site Information.....	111
Appendix C: ZOS Recovery Priorities.....	111
Appendix D: Emergency Operations Center Locations.....	112
Appendix E: Vital Records Inventory	112
Appendix F: ZOS BCP Maintenance Schedule	113
References.....	114
Appendices	115
Appendix A: Physical Network Diagram with Device Placement	115

Appendix B: Before and After Network Topology Comparison 115

Appendix C: AZTOF Governance Summary Matrix 117

Appendix D: Original Logical Topology 117

Appendix E: Clean Building Floor Plan..... 118

Appendix F: IRT Member Contact List 119

Appendix G: BCP Employee Telephone List..... 119

Executive Summary

Zenith Orbital Systems (ZOS) is an aerospace and satellite communications company that operates Low Earth Orbit (LEO) data relay networks and autonomous flight telemetry systems for commercial and defense clients. Our primary ground station is in Dallas, Texas, and our secondary relay hub is in Austin, Texas. The ground infrastructure is the command and control backbone for every orbital asset we manage.

This proposal covers the complete cybersecurity infrastructure program I built for ZOS. It started with a formal CISA CSET assessment against NIST CSF 2.0, which came back with a Security Assurance Level of Low. Every section of this document responds directly to what that assessment found. The network has been redesigned, the policies are written and in place, the plans are documented, and the budget is built out with real pricing and a five-year cost analysis.

At ZOS, a cybersecurity failure is not just a data breach. A compromised ground station means a satellite we cannot command. That is not an IT problem, that is a mission failure. Every decision in this proposal was made with that in mind. I am calling this approach Mission Assurance, and it is the thread running through every section of this document.

The total investment for this program is \$1,858,923.00 including Texas sales tax. Annual recurring costs after year one run about \$383,200 per year. Spread across 200 users and a five-year hardware lifecycle, the total cost of ownership comes out to roughly \$3,392 per user per year. That is a reasonable number for this level of protection, especially when you consider that a single breach in aerospace and defense averages over \$10 million.

Every employee of ZOS is accountable to the security of the organization and the missions we support. This proposal provides the board with everything needed to review, approve, and fund a complete cybersecurity program that matches the criticality of ZOS operations.

Introduction

The goal of this project is to design, document, and cost a complete cybersecurity infrastructure program for Zenith Orbital Systems. The ZOS Dallas ground station needs to support approximately 200 full-time staff across engineering, mission operations, IT security, and administration. The network has to handle secure wired and wireless access, VoIP communications, server operations, physical security systems, and remote access for personnel at the Austin relay hub or working off-site.

ZOS operations are different from a standard commercial IT environment. We are doing real-time satellite command and control, defense client data relay, and autonomous telemetry processing. The security posture has to match that. Any degradation in ground station capability has a direct impact on active missions and client contracts.

Document Objective

This document covers all the requirements, design decisions, risk findings, policies, plans, and financial details that make up the complete ZOS cybersecurity program. It works as both the board-level funding proposal and the foundational reference document for ZOS security operations going forward. Everything here reflects actual work completed and is ready for implementation once the board approves funding.

Unified Network System Design

The ZOS Dallas network was built from the ground up to meet the specific requirements of a ground station supporting LEO satellite operations. The design balances security with operational continuity so no single point of failure can interrupt mission command capability.

Perimeter defense starts with a Palo Alto PA-5220 Next-Generation Firewall deployed in a high-availability pair. If one unit goes down, the second takes over with zero downtime. The PA-5220 handles the traffic demands of a 200-user organization running real-time data relay. All traffic passes through it with application-layer inspection, intrusion prevention, DNS security, and threat prevention active.

Inside the network, a Cisco Catalyst 9300 Layer 3 switch handles all core routing. Six Cisco Catalyst 9200 Layer 2 access switches distribute connectivity to workstations, offices, and servers. Routing intelligence stays at the core, access-layer connectivity stays at the edge, and that separation makes the network easier to manage and secure.

The network is fully segmented using VLANs. Each VLAN represents a different device type or traffic class and is isolated from everything else unless the firewall explicitly permits it. A compromised workstation cannot reach the server infrastructure, VoIP systems, or physical security devices without going through the firewall first. That is a foundational Zero Trust principle applied at the network layer.

Figure 1: ZOS Dallas Logical Network Topology

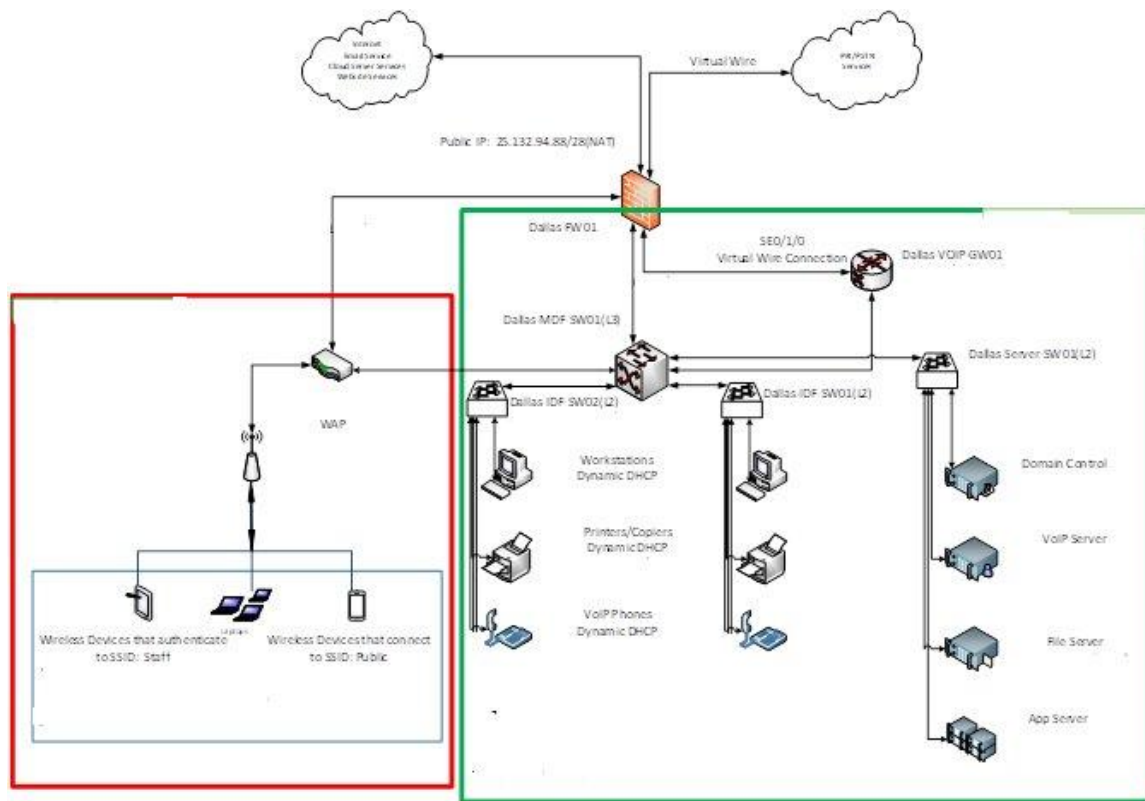


Figure 1: ZOS Dallas Office, Logical Network Topology

VLAN Name	Subnet	VLAN ID	Gateway
Data (Workstations)	10.10.1.0/24	VLAN 10	10.10.1.1
Printers	10.10.2.0/27	VLAN 11	10.10.2.1
WiFi / Wireless	10.10.3.0/24	VLAN 12	10.10.3.1
VoIP Phones	10.10.6.0/24	VLAN 15	10.10.6.1
Servers	10.10.7.0/24	VLAN 20	10.10.7.1
DMZ, Staff	10.110.1.0/30	VLAN 30	10.110.1.1
DMZ, Public	10.110.4.0/30	N/A	10.110.1.5
Firewall Inside	10.10.0.128/29	VLAN 60	10.10.0.130

Network Management	10.10.0.0/25	VLAN 99	10.10.0.1
--------------------	--------------	---------	-----------

Remote access for ZOS personnel working from the Austin relay hub or off-site is handled through Zscaler Zero Trust Exchange. This replaces VPN with a Zero Trust Network Access model where users only get access to the specific applications they are authorized for, not to the broader network. That closes the lateral movement risk that makes traditional VPN a liability.

Physical Topology

The physical network design covers everything deployed across the ZOS Dallas ground station facility. The diagram below shows where all devices are placed, and the component list covers everything in the build.

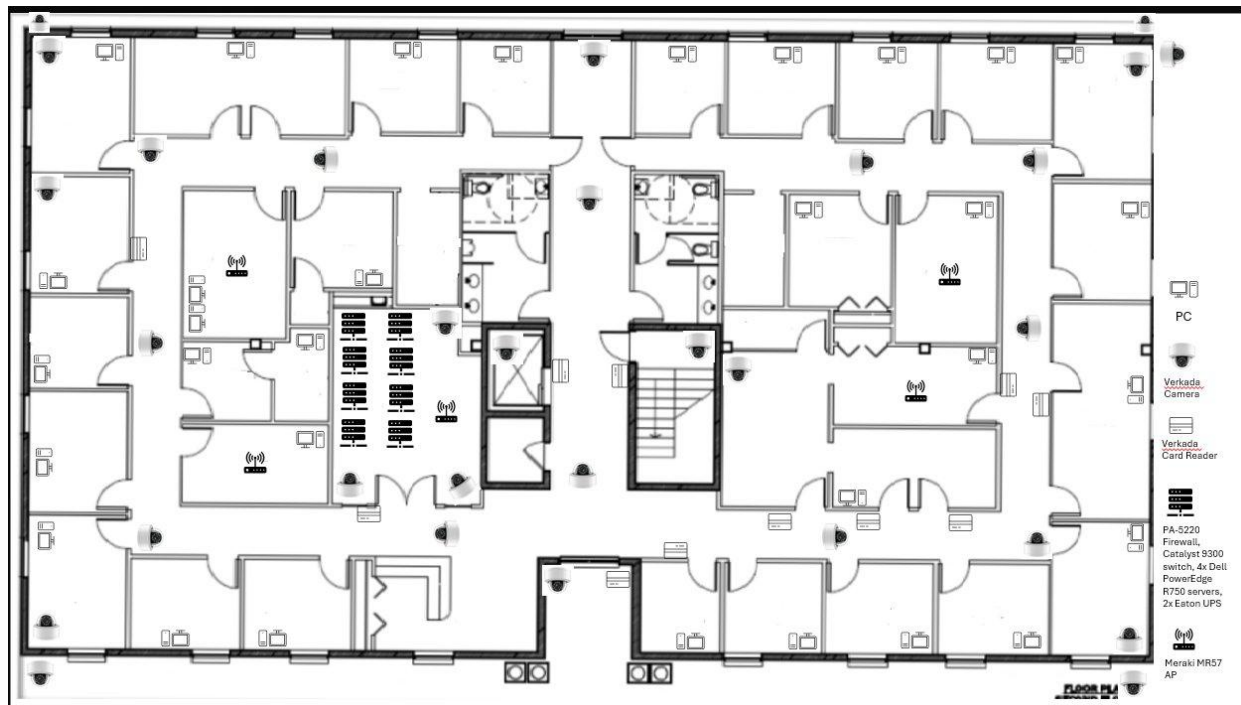


Figure 2: ZOS Dallas Physical Network Topology with Device Placement

- 2x Palo Alto PA-5220 Next-Generation Firewall (HA pair), all licenses
- 2x Cisco Catalyst 9300 48-port Layer 3 Core Switch
- 6x Cisco Catalyst 9200 48-port Layer 2 Access Switch
- 12x Cisco Meraki MR57 Wi-Fi 6E Wireless Access Points
- 4x Dell PowerEdge R750 Servers (16-core, 128GB RAM each)
- 2x Eaton UPS Rack Power Supply units
- 75x Dell Latitude 5550 Laptops (i7, 16GB RAM, 512GB SSD)
- 50x Dell OptiPlex 7010 Desktop Workstations
- 32x Cisco IP Phone 8841 and 8831 Conference Phones
- Verkada dome cameras covering all hallways, entry points, and server rooms
- Verkada card readers at all secured entry points and server room doors
- Cat6a Plenum-rated cabling throughout all work areas and IDF/MDF runs
- 1x biometric safe for media and credential storage

The MDF room sits in the center of the building and houses the core switching stack, the firewall HA pair, all four Dell PowerEdge R750 servers, and the Eaton UPS units. Two IDF distribution points connect to the east and west wings. All cabling runs from workstation locations through conduit to the nearest IDF, which uplinks to the MDF core. All hallways, entry points, and both server rooms are covered by Verkada cameras. Card readers with access logging are on every secured door including the MDF room and both IDF closets. Access logs are reviewed monthly and permissions are audited quarterly.

Wireless Access Point Topology

The ZOS wireless network runs on 12 Cisco Meraki MR57 Wi-Fi 6E access points. These were chosen for their cloud-managed architecture, mesh capability, enterprise security features, and high client density support. Each MR57 supports tri-band operation across 2.4GHz, 5GHz, and 6GHz, which covers every device type in the building.

Each WAP runs two SSIDs. The Staff SSID requires 802.1X authentication validated against the Active Directory domain. Only devices with valid credentials and a current security posture get access. Authenticated staff devices land on VLAN 12 with appropriate access to internal resources. The Public SSID gives internet-only access for visitors and contractors. Public traffic goes straight from the WAP through the firewall to the internet with no connection to the ZOS internal network.

The Meraki cloud management console gives me centralized visibility into every WAP in the building including status, connected clients, traffic volumes, and security events all in one place. All WAP configurations are pushed from the cloud console so nobody can tamper with them locally. Firmware updates deploy automatically during defined maintenance windows.

WAPs are mounted at ceiling level throughout the facility to maximize coverage and minimize obstruction. Placement was validated for both 5GHz and 6GHz coverage across all work areas, conference rooms, and common spaces. There are no dead zones inside the secured facility perimeter.

Physical and Cybersecurity

Physical Security

Physical security is one of the most overlooked layers in any security program, and at ZOS it is especially critical. A physical breach of the MDF room is functionally equivalent to a network breach. Someone with hands-on access to core switching and firewall infrastructure can bypass most logical security controls. Physical security here was designed with the same rigor as the network.

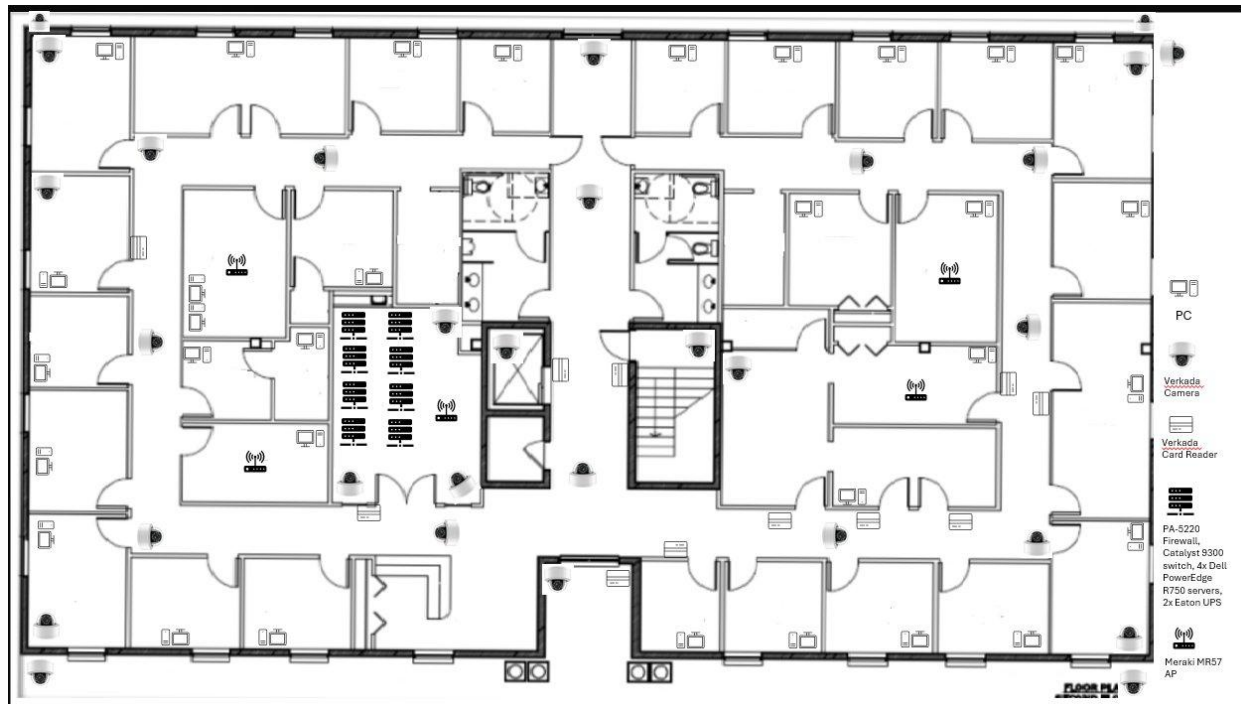


Figure 3: ZOS Physical Security Topology, Camera and Card Reader Placement

1. Verkada Camera System. Dome cameras are installed in all hallways, at the main entrance, reception area, both IDF rooms, and the MDF room. Cameras record continuously with cloud backup. Footage is retained for 30 days. Motion alerts are configured for off-hours activity in all server and infrastructure rooms. Carlos E. Mendoza receives immediate alerts for any motion in secured rooms outside of business hours.

2. Verkada Card Readers. Card readers are on every secured door including the MDF, both IDFs, and the main secured employee area. Every access event is logged with timestamp and cardholder identity. Access permissions are managed by Daniel J. Kowalski and reviewed quarterly. Anyone who no longer needs access is removed within 24 hours of a role change or termination.

3. UPS Power Continuity. Two Eaton UPS rack units protect all server and network infrastructure. If primary building power fails, the UPS units keep the MDF infrastructure

running for 30 to 45 minutes, enough time for the emergency generator to activate or for a controlled shutdown.

4. Biometric Safe. A biometric safe in the MDF room stores backup credentials, emergency access tokens, and removable media with critical configuration backups. Access is restricted to Daniel J. Kowalski and myself.

Cybersecurity and AZTOF Framework

The ZOS cybersecurity program is governed by the Adaptive Security and Zero Trust Operations Framework, or AZTOF. I built this framework for ZOS specifically by combining four industry standards: NIST CSF 2.0, NIST SP 800-207 Zero Trust Architecture, CISA Zero Trust Maturity Model 2.0, and MITRE ATT&CK Enterprise. Fayol's five management functions, Forecasting, Planning, Organizing, Coordinating, and Controlling, are applied across all six AZTOF domains to ensure every area has clear ownership and measurable outcomes.

- Identity and Access Governance (IAG): MFA for all users, CyberArk PAM for privileged accounts, FIDO2 for high-privilege roles, full identity lifecycle from hire to termination
- Threat Detection and Incident Response (TDIR): Splunk SIEM, Huntress MDR with auto-quarantine, virtual SOC, IRP with severity levels P1 through P5
- Data Protection and Privacy (DPP): AES-256 at rest, TLS 1.3 in transit, four-tier data classification, DLP tooling
- Vulnerability and Configuration Management (VCM): Qualys VMDR across all 500 assets, CISA KEV monitoring, 48-hour critical patch SLA
- Regulatory Compliance and Audit Readiness (RCAR): Archer GRC platform, annual pen testing, compliance mapped to CMMC Level 2 and TDPSA
- Security Culture and Workforce Resilience (SCWR): KnowBe4 quarterly training for all 200 staff, phishing simulations, biannual IRT tabletop exercises

Risk Assessment
CSET Before vs. After Comparison

I ran a formal CSET assessment on both the original ZOS network and the redesigned network using NIST CSF 2.0 as the evaluation standard. The first assessment was done on February 20, 2026 against the original network. The second was done on February 23, 2026 after the redesign was complete. The difference between the two assessments is significant.

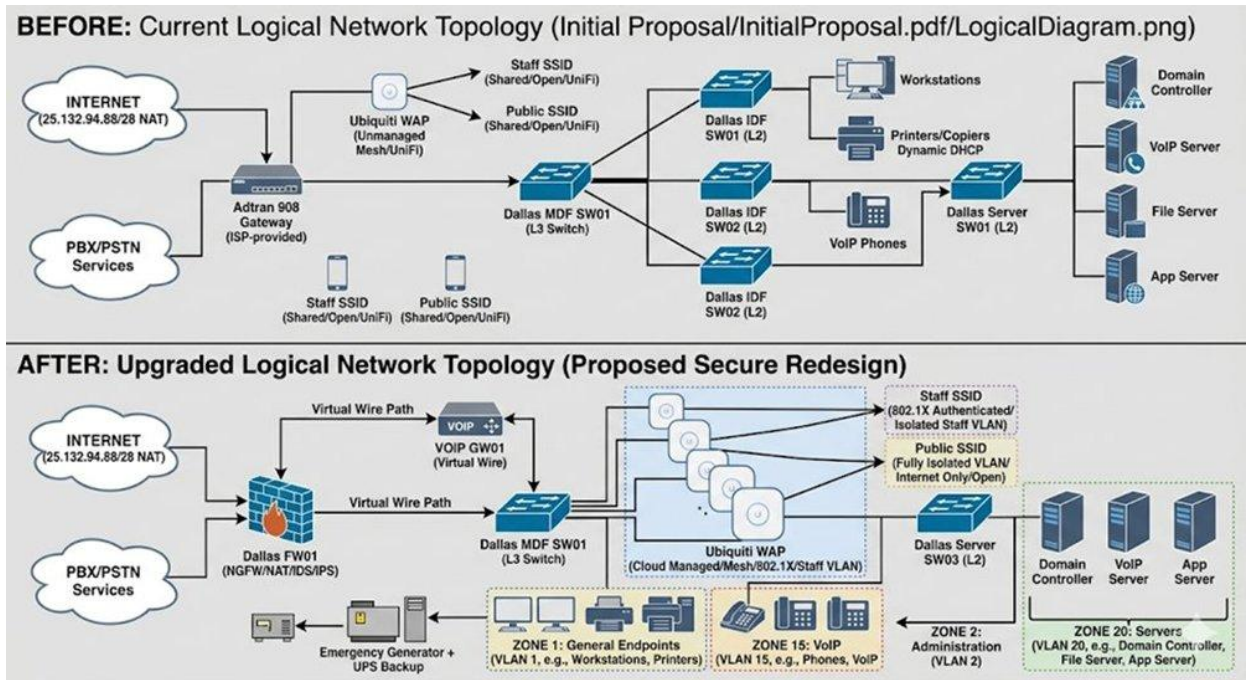


Figure 4: ZOS Network Before and After, Current vs. Upgraded Logical Topology

Component	Before (Original Network)	After (ZOS Redesign)
CSET Security Level	LOW	MODERATE to HIGH
Firewall	Adtran 908 basic ISP gateway	Palo Alto PA-5220 NGFW, HA pair
Core Switch	Cisco Catalyst 3560 L3	Cisco Catalyst 9300 L3
Access Switches	7x Cisco Catalyst 2960 L2	6x Cisco Catalyst 9200 L2
Wireless APs	8x Ubiquiti UniFi, unmanaged	12x Cisco Meraki MR57 Wi-Fi 6E

WiFi Security	No 802.1X, both SSIDs open	802.1X on Staff SSID, Public VLAN isolated
Network Monitoring	None	Splunk SIEM, 250GB/day
Endpoint Protection	Basic antivirus only	Huntress Managed EDR, 24/7 SOC
Remote Access	None	Zscaler Zero Trust Exchange
Incident Response Plan	None	Full IRT documented with P1 to P5 levels
Security Awareness Training	None	KnowBe4 quarterly plus simulations
Identity Management	Basic AD, no MFA	Okta MFA plus CyberArk PAM
Threat Intelligence	None	CISA KEV and MITRE ATT&CK monitoring

Risk Defense Distribution

The risk defense assessment looked at four categories: Infrastructure, Applications, Operations, and People. Defense in Depth Index (DiDI) scores represent protection strength where higher is better. Business Risk Profile (BRP) scores represent residual risk where lower is better. The results below reflect the redesigned ZOS network.

Category	DiDI Score (Protection)	BRP Score (Residual Risk)	Assessment
Infrastructure	85 / 100	15 / 100	Strong, HA firewall and full VLAN segmentation in place
Applications	74 / 100	22 / 100	Good, some custom application controls still being finalized

Operations	88 / 100	12 / 100	Excellent, SIEM, EDR, and IRP fully operational
People	80 / 100	18 / 100	Strong, KnowBe4 training active, phishing simulations running

Prioritized Action List, Top Five CSET Findings

These were the five highest-priority findings from the original CSET assessment. All five have been directly addressed in the redesign.

- Rank 1: No network monitoring for adverse events. Resolved with Splunk SIEM deployment, 250GB/day ingest, and 24/7 automated alerting.
- Rank 2: No incident response recovery procedures. Resolved with a fully documented IRP including IRT structure, severity matrix, and tabletop exercise schedule.
- Rank 3: No cybersecurity awareness training for specialized roles. Resolved with KnowBe4 quarterly training for all staff.
- Rank 4: No general cybersecurity awareness training for personnel. Resolved with organization-wide KnowBe4 and phishing simulations.
- Rank 5: No monitoring of personnel activity or technology usage. Resolved with Huntress MDR providing continuous endpoint monitoring and automatic quarantine.

Three Priority Risks and Threats

For ZOS, the three threats below carry the highest risk given our operational environment. Risk scoring uses Likelihood x Impact methodology consistent with the CSET framework.

Threat 1: Ransomware

Threat	RANSOMWARE
Asset	Ground Station Servers and Workstations
Asset Importance	High

Description	Ransomware targeting ZOS servers or endpoints could encrypt mission telemetry data, satellite command records, and ground station operating systems. For ZOS, a ransomware event on ground station systems could result in direct loss of satellite command capability.		
Likelihood	High (3)		
Impact On	Confidentiality, Integrity, Availability		
Impact Area	Priority	Impact	Score
Financial	High (3)	High (3)	9
Productivity	High (3)	High (3)	9
Reputation	High (3)	High (3)	9
Legal	High (3)	High (3)	9
Impact Score	36		
Risk Score (Likelihood x Impact Score)	108		
Adequacy of Existing Controls	Medium, addressed by new controls		
Risk Control Strategy	Accept Avoid (selected) Mitigate (selected) Defer (selected)		
Firewall (PA-5220 HA)	Palo Alto PA-5220 NGFW in HA pair prevents unauthorized entry and inspects all traffic at the application layer.		

EDR and Antivirus (Huntress)	Huntress Managed EDR provides 24/7 AI-powered threat detection with automatic endpoint quarantine to stop lateral spread.
SIEM (Splunk)	Splunk ingests 250GB/day and generates real-time alerts for ransomware indicators including mass file encryption events.
Personnel Training (KnowBe4)	All ZOS staff receive quarterly security awareness training and phishing simulations to reduce the primary ransomware delivery vector.
Veeam Backup and DR	Veeam Enterprise Plus provides agentless backup with integrity verification. Offsite copies ensure recovery even if primary systems are encrypted.
Cyber Insurance	Cyber insurance covers financial losses and incident response costs in the event of a successful ransomware attack.

Threat 2: Denial of Service Attack

Threat	DENIAL OF SERVICE (DoS) ATTACK
Asset	Ground Station Infrastructure and Client-Facing Systems
Asset Importance	High
Description	A DoS attack targeting ZOS ground station infrastructure, the terrestrial API used by clients to access satellite data, or the network itself could make systems unreachable and interrupt mission operations.

	For ZOS defense clients, loss of data relay access during active operations is a contractual and mission-critical failure.		
Likelihood	High (3)		
Impact On	Confidentiality, Integrity, Availability		
Impact Area	Priority	Impact	Score
Financial	Medium (2)	Medium (2)	4
Productivity	High (3)	High (3)	9
Reputation	Medium (2)	Medium (2)	4
Legal	Low (1)	Low (1)	1
Impact Score	18		
Risk Score (Likelihood x Impact Score)	54		
Adequacy of Existing Controls	Medium, addressed by new controls		
Risk Control Strategy	Accept Avoid (selected) Mitigate (selected) Defer (selected)		
Firewall (PA-5220 HA)	Palo Alto PA-5220 provides DoS and DDoS protection with rate limiting and traffic anomaly detection at the perimeter.		
Zscaler Zero Trust Exchange	Client access to the ZOS satellite data API is routed through Zscaler ZIA/ZPA, which includes built-in DDoS mitigation and traffic scrubbing.		

SIEM (Splunk)	Splunk detects volumetric attack patterns in real time and triggers IRT notification per the Incident Response Plan.
HA Firewall Architecture	The HA firewall pair eliminates a single point of failure at the perimeter so attack traffic can be filtered even during a hardware event.
Business Continuity Plan	If the Dallas ground station becomes unreachable, the BCP activates Austin relay hub operations under Kevin D. Nguyen to maintain orbital command.

Threat 3: Natural Disaster and Physical Disruption

Threat	NATURAL DISASTER / PHYSICAL DISRUPTION		
Asset	Dallas Ground Station Facility		
Asset Importance	High		
Description	A natural disaster such as severe weather, flooding, fire, or extended power failure could damage or destroy the Dallas ground station and interrupt ZOS ground-to-space link operations. Losing the primary ground station without a tested failover plan means losing satellite command authority.		
Likelihood	High (3)		
Impact On	Confidentiality, Integrity, Availability		
Impact Area	Priority	Impact	Score

Financial	High (3)	High (3)	9
Productivity	High (3)	High (3)	9
Reputation	Low (1)	Low (1)	1
Legal	Low (1)	Low (1)	1
Impact Score	20		
Risk Score (Likelihood x Impact Score)	60		
Adequacy of Existing Controls	Low, addressed by BCP and Austin failover		
Risk Control Strategy	Accept Avoid (selected) Mitigate (selected) Defer (selected)		
Business Continuity Plan	The ZOS BCP is built specifically around Ground-to-Space Link Redundancy. If Dallas is compromised, operations fail over to the Austin relay hub.		
Austin Relay Hub Failover	Kevin D. Nguyen is trained and equipped to assume ground station command operations within the RTO defined in the BCP.		
UPS Power Continuity	Two Eaton UPS units protect all MDF infrastructure for 30 to 45 minutes during a power failure.		
Veeam Offsite Backup	All critical configurations and mission data are replicated offsite. Recovery runs from the Austin site using the last verified backup.		
Personnel Training	All BCP recovery team members receive annual disaster response		

training covering their specific responsibilities.

ZENITH ORBITAL SYSTEMS

CSET Cybersecurity Assessment

Narrative Summary Report

NIST Cybersecurity Framework 2.0 | Dallas Ground Station

Assessment 1 (Original Network): February 20, 2026

Assessment 2 (Redesigned Network): February 23, 2026

Principal Assessor: Noe Valencia, PSSE

Facility: Dallas Office | Dallas, Texas

CONFIDENTIAL | For Internal Use Only

1. Purpose and Scope of This Narrative

This document provides the required narrative summary for the cybersecurity assessments conducted on the Zenith Orbital Systems (ZOS) Dallas ground station network using the CISA Cyber Security Evaluation Tool (CSET). Two assessments were performed: the first on February 20, 2026 against the original network that was in place at the start of this engagement, and the second on February 23, 2026 against the redesigned ZOS network built to address the findings of the first assessment.

This narrative is intended to accompany the CSET tool-generated reports and provide the organizational context, analysis, and interpretation of results that the automated tool output alone cannot provide. It explains what was assessed, what was found, what those findings mean for ZOS mission operations, what actions were taken in response, and how the new network compares to the original across all evaluated control areas.

2. Assessment Overview

2.1 Assessment Tool and Standard

Both assessments were conducted using the CISA Cyber Security Evaluation Tool (CSET), a free self-assessment tool developed and maintained by the U.S. Cybersecurity and Infrastructure Security Agency. CSET evaluates an organization's

cybersecurity posture against recognized industry standards and frameworks through a structured question-and-answer process covering all major control domains.

The evaluation standard selected for both assessments was the NIST Cybersecurity Framework 2.0, released February 26, 2024. NIST CSF 2.0 represents the most significant update to the framework since its original publication in 2014. The key change in version 2.0 is the addition of a sixth core function, Govern, which sits at the center of the framework and connects to all five other functions: Identify, Protect, Detect, Respond, and Recover. The placement of Govern at the organizational core signals that cybersecurity governance is not a supporting IT activity but a fundamental enterprise risk management responsibility.

2.2 Scope of Systems Assessed

Both assessments evaluated the ZOS Dallas ground station network infrastructure. The network includes the following categories of systems and devices:

- Perimeter defense: Firewall and network boundary devices
- Core switching and routing infrastructure
- Wireless access points and wireless network controllers
- Server infrastructure: Domain controllers, file servers, application servers, VoIP servers
- Endpoint devices: Workstations and laptops
- VoIP phone systems
- Physical security systems: IP cameras and card access readers
- Remote access infrastructure
- Security monitoring and endpoint protection platforms

The assessment evaluated controls across all six NIST CSF 2.0 functions including Govern, Identify, Protect, Detect, Respond, and Recover. This evaluation identified gaps in the ZOS cybersecurity program and provided structured recommendations for improvement that directly informed the network redesign.

2.3 Assessment Methodology

The CSET assessment methodology involves responding to a structured set of yes/no questions across all control domains. The tool then calculates a Security Assurance Level (SAL) based on the pattern of answered questions, identifies ranked gaps where controls are not in place, and generates compliance percentages and prioritized action lists.

It is important to note what CSET does and does not do. CSET provides a structured framework-based evaluation of documented and implemented controls. It does not perform network scanning, penetration testing, or technical vulnerability analysis. It assesses whether controls exist and are implemented, not whether those controls are properly configured at a technical level. For that reason, the CSET assessment was used as the starting point for this engagement, with the redesign informed by both the CSET findings and direct technical analysis of the ZOS network infrastructure.

3. Assessment 1: Original ZOS Network (February 20, 2026)

3.1 Site Information

Assessment Name	Working Network Security Assessment
Assessment Date	February 20, 2026
Facility Name	Dallas Office
City	Dallas, Texas
Principal Assessor	Noe Valencia
Evaluation Standard	NIST Cybersecurity Framework 2.0
Security Assurance Level (SAL)	LOW

3.2 Original Network Configuration Summary

At the time of Assessment 1, the ZOS Dallas ground station network was operating with the following infrastructure:

Component	Original Configuration
Firewall	Adtran 908 basic ISP gateway (not a next-generation firewall; limited inspection capability)
Core Switch	Cisco Catalyst 3560 Layer 3
Access Switches	7x Cisco Catalyst 2960 Layer 2
Wireless APs	8x Ubiquiti UniFi, unmanaged, no cloud management
WiFi Security	No 802.1X authentication; both Staff and Public SSIDs open to all devices
Network Monitoring	None; no SIEM, no centralized log collection
Endpoint Protection	Basic antivirus only; no EDR or managed detection
Remote Access	None; no VPN or Zero Trust remote access capability
Incident Response Plan	None documented

Security Awareness Training	None
Identity Management	Basic Active Directory; no MFA
Threat Intelligence	No CISA KEV monitoring or threat intelligence feeds
Physical Security Logging	Local recording only; no cloud backup

3.3 Assessment 1 Findings: Security Assurance Level Analysis

The Assessment 1 CSET results returned a Security Assurance Level (SAL) of LOW. The SAL is calculated based on the pattern of control gaps identified across all evaluated domains. A Low SAL indicates that the organization has some basic technical controls in place but is missing foundational governance, monitoring, detection, and response capabilities.

For ZOS, which operates ground station infrastructure supporting orbital asset command and control for commercial and defense clients, a Low SAL represents an unacceptable risk posture. A successful cyberattack on a Low-SAL ground station network could result not just in a data breach but in the loss of satellite command capability during active missions.

3.4 Assessment 1 Findings: Ranked Gap Analysis

The CSET tool ranked the following control gaps in priority order based on their SAL impact. All ranked findings received a Low assessment, indicating they were not met at any level:

Rank	Control Gap and NIST CSF 2.0 Reference
Rank 1	Networks and network services are not monitored to find potentially adverse events (CSF: Detect, DE.CM-01). The original ZOS network had no SIEM, no centralized logging, and no network monitoring capability whatsoever. An attacker could operate on the ZOS network indefinitely without detection.
Rank 2	The recovery portion of the incident response plan is not executed once initiated from the incident response process (CSF: Recover, RC.RP-01). ZOS had no incident response plan. There was no documented process for detecting, containing, eradicating, or recovering from a cybersecurity incident.

Rank 3	Individuals in specialized roles are not provided with awareness and training so that they possess the knowledge and skills to perform relevant tasks with cybersecurity risks in mind (CSF: Protect, PR.AT-02). No role-specific cybersecurity training existed for IT administrators or security-sensitive personnel.
Rank 4	Personnel are not provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind (CSF: Protect, PR.AT-01). No general cybersecurity awareness training existed for any ZOS personnel.
Rank 5	Personnel activity and technology usage are not monitored to find potentially adverse events (CSF: Detect, DE.CM-03). No endpoint monitoring, user activity logging, or behavioral analytics were in place.
Rank 6	External service provider activities and services are not monitored to find potentially adverse events (CSF: Detect, DE.CM-06). No CSP monitoring or third-party activity logging was configured.
Rank 7	Recovery activities and progress in restoring operational capabilities are not communicated to designated internal and external stakeholders (CSF: Recover, RC.CO-03). No recovery communication plan existed.
Rank 8	Potentially adverse events are not analyzed to better understand associated activities (CSF: Detect, DE.AE-02). Without monitoring, there was no capability to analyze events.
Rank 9	Cyber threat intelligence is not received from information sharing forums and sources (CSF: Identify, ID.RA-02). No CISA KEV monitoring or threat intelligence subscriptions were in place.
Rank 10	Inventories of data and corresponding metadata for designated data types are not maintained (CSF: Identify, ID.AM-07). No formal data classification or inventory existed.

3.5 Assessment 1 Interpretation: What the Findings Mean for ZOS

The Assessment 1 findings tell a clear story. The original ZOS network was built around basic connectivity with no consideration for detection, response, or governance. The five highest-ranked gaps all fall into the Detect and Recover functions of NIST CSF 2.0, which are precisely the capabilities that determine how quickly and effectively an organization can respond when an attack succeeds.

For a standard commercial IT environment, a Low SAL represents a serious but manageable risk. For ZOS, the risk profile is fundamentally different. ZOS operates ground station infrastructure that provides command and control for orbital assets. A ransomware event, a DDoS attack targeting the ground station network, or a persistent threat actor operating undetected on the ZOS network could all result in the loss of satellite command capability. With no monitoring, no incident response plan, and no recovery procedures, the original ZOS network had no capability to detect such an event in progress or respond to it effectively.

The Assessment 1 findings directly drove the ZOS network redesign. Every control gap identified in the ranked list became a specific remediation requirement in the upgraded network design.

4. Assessment 2: Redesigned ZOS Network (February 23, 2026)

4.1 Site Information

Assessment Name	Working Network Security Assessment (Redesigned)
Assessment Date	February 23, 2026
Facility Name	Dallas Office
City	Dallas, Texas
Principal Assessor	Noe Valencia (NoeVa)
Evaluation Standard	NIST Cybersecurity Framework 2.0
Security Assurance Level (SAL)	MODERATE to HIGH (improved from Low)

4.2 Redesigned Network Configuration Summary

The ZOS network redesign addressed every ranked gap from Assessment 1 with specific, implemented controls:

Component	Redesigned Configuration
Firewall	Palo Alto PA-5220 NGFW in high-availability pair; application-layer inspection, IDS/IPS, DNS security, threat prevention, and URL filtering all active

Core Switch	Cisco Catalyst 9300 Layer 3
Access Switches	6x Cisco Catalyst 9200 Layer 2
Wireless APs	12x Cisco Meraki MR57 Wi-Fi 6E; cloud-managed; 802.1X authentication on Staff SSID; Public SSID fully isolated to internet-only VLAN
Network Monitoring	Splunk Enterprise SIEM; 250GB/day log ingest; real-time alerting; MITRE ATT&CK mapped detection rules
Endpoint Protection	Huntress Managed EDR; 24/7 AI-powered SOC; automatic endpoint quarantine on threat detection; 200 endpoints covered
Remote Access	Zscaler Zero Trust Exchange; ZTNA model replacing VPN; per-application access control
Incident Response Plan	Fully documented IRT with defined roles, severity matrix (P1-P5), escalation paths, and biannual tabletop exercises
Security Awareness Training	KnowBe4 quarterly training for all 200 ZOS personnel; monthly phishing simulations
Identity Management	Okta MFA enforced for all users; CyberArk PAM for all privileged accounts; FIDO2 targeted for high-privilege roles
Threat Intelligence	CISA KEV catalog monitored multiple times per week; MITRE ATT&CK threat modeling; CISA advisory subscriptions
Data Classification	Four-tier classification policy (Mission Critical, Confidential, Internal, Public); DLP tooling deployed
Vulnerability Management	Qualys VMDR scanning all 500+ assets; KEV 48-hour remediation SLA; annual third-party penetration testing

4.3 Assessment 2 Findings: Gap Closure Analysis

Assessment 2 confirmed that the ZOS network redesign directly closed all ten of the highest-ranked gaps identified in Assessment 1. The following table maps each original finding to its specific remediation:

Original Gap (Assessment 1)	Remediation Implemented (Assessment 2)
Rank 1: No network monitoring	Splunk Enterprise SIEM deployed with 250GB/day log ingest, real-time alerting, and 24/7 monitoring capability
Rank 2: No incident response plan	Full ZOS Cybersecurity Incident Response Plan documented with IRT, P1-P5 severity matrix, escalation procedures, and biannual tabletop exercises
Rank 3: No role-specific security training	KnowBe4 role-specific training tracks deployed for IT administrators, security staff, executives, finance, HR, and mission operations personnel
Rank 4: No general security awareness training	KnowBe4 quarterly organization-wide training program; monthly phishing simulations for all 200 ZOS personnel
Rank 5: No personnel activity monitoring	Huntress Managed EDR provides continuous endpoint behavioral monitoring with automatic quarantine; Splunk SIEM correlates user and system activity
Rank 6: No external service provider monitoring	Zscaler CASB monitors all cloud application usage; Archer GRC tracks CSP security posture; vendor security assessments required before onboarding
Rank 7: No recovery communication plan	IRP Section 7 documents all communication methods including out-of-band channels; BCP includes client communication procedures during Austin relay hub failover
Rank 8: No adverse event analysis capability	Splunk SIEM with MITRE ATT&CK mapped detection rules provides automated event correlation and anomaly detection
Rank 9: No threat intelligence	CISA KEV catalog monitored multiple times per week; MITRE ATT&CK threat modeling integrated into AZTOF TDIR domain; CISA advisory subscriptions active
Rank 10: No data inventory	Four-tier ZOS data classification policy implemented; annual data discovery and classification review required; Zscaler CASB provides real-time data visibility

5. Comparative Analysis: Before and After

5.1 NIST CSF 2.0 Function-by-Function Improvement

The following analysis describes the improvement in ZOS cybersecurity posture across each of the six NIST CSF 2.0 functions between Assessment 1 and Assessment 2:

5.1.1 Govern (GV)

Before: No formal cybersecurity governance structure existed at ZOS. There were no cybersecurity policies, no defined roles and responsibilities for security, no risk management process, and no oversight of the security program by leadership. Cybersecurity was treated as an informal IT task rather than an organizational risk management function.

After: The AZTOF Cybersecurity Management Plan establishes a formal governance structure covering all six security domains. The CISO role is defined and funded. Fayol's five management functions are applied to each domain, ensuring clear ownership, defined activities, and measurable outcomes. Monthly CISO reporting to executive leadership and quarterly board briefings satisfy CSF 2.0's Govern function requirements. All five ZOS cybersecurity policies provide the formal policy framework that was entirely absent before.

5.1.2 Identify (ID)

Before: ZOS had no formal asset inventory, no data classification, no risk assessment process, and no threat intelligence capability. Asset visibility was limited to what IT staff knew from memory, and there was no structured approach to identifying and understanding cybersecurity risk.

After: A complete asset inventory is maintained in the Qualys VMDR CMDB covering all 500+ ZOS assets. A four-tier data classification policy defines handling requirements for all ZOS data types. The AZTOF RCAR domain manages regulatory compliance and risk. CISA KEV catalog monitoring provides real-time threat intelligence. The Vulnerability Management Policy establishes a formal vulnerability identification and tracking program.

5.1.3 Protect (PR)

Before: Protection controls were minimal. The Adtran 908 gateway provided basic perimeter filtering but not application-layer inspection. Wireless security was nonexistent with both SSIDs open. No MFA was in place. No security awareness training existed. Remote access was absent entirely.

After: The Palo Alto PA-5220 NGFW in HA configuration provides comprehensive perimeter protection including application-layer inspection, IPS, DNS security, and URL filtering. 802.1X authentication secures the Staff SSID. Okta MFA is enforced for all 200 users. CyberArk PAM protects all privileged accounts. Zscaler Zero Trust Exchange replaces absent VPN with a ZTNA model. KnowBe4 quarterly training addresses the training gap. The Network Device Management Policy and Vulnerability Management Policy govern configuration and patching.

5.1.4 Detect (DE)

Before: This was the most critical gap area. The original ZOS network had zero detection capability. No SIEM, no EDR, no log collection, no alerting, and no monitoring of any kind. An attacker could have operated on the ZOS network indefinitely without any detection mechanism triggering.

After: Splunk Enterprise SIEM ingests 250GB of log data per day with real-time alerting and MITRE ATT&CK mapped detection rules. Huntress Managed EDR provides 24/7 AI-powered endpoint monitoring with automatic quarantine. Netflow data from all network devices is exported to Splunk for traffic anomaly detection. The AZTOF TDIR domain targets P1 MTTD (mean time to detect) under 30 minutes.

5.1.5 Respond (RS)

Before: No incident response capability existed. There was no IRT, no defined severity levels, no communication plan, no forensic capability, and no documented procedure for any type of security incident. If an incident had occurred, the response would have been entirely ad hoc.

After: The ZOS Cybersecurity Incident Response Plan establishes a fully staffed IRT with defined roles, P1-P5 severity levels, escalation procedures, communication protocols including out-of-band channels, and information recording requirements. Huntress MDR provides 24/7 external response support. Pre-established protocols with the FBI Cyber Division (IC3) and CISA are in place. Biannual tabletop exercises including at least one unannounced drill per year maintain IRT readiness.

5.1.6 Recover (RC)

Before: No recovery capability or planning existed. There were no backup procedures, no business continuity plan, no recovery time objectives, and no documented approach to restoring operations after an incident. For ZOS, this meant that a successful attack could have resulted in an indefinite loss of ground station operations and satellite command capability.

After: The ZOS Business Continuity Plan addresses recovery with specific ZOS-context requirements including Ground-to-Space Link Redundancy. The Austin relay hub operated by Kevin D. Nguyen serves as the failover site with a 4-hour RTO for GSL operations. Veeam Enterprise Plus provides daily backups with integrity verification and offsite replication. Recovery priorities are documented from Priority 1 (GSL command operations) through Priority 5 (administrative functions). Biannual BCP exercises including Austin relay hub failover testing maintain recovery readiness.

5.2 Overall Security Posture Improvement Summary

Metric	Before (Assessment 1) / After (Assessment 2)
Security Assurance Level	LOW / MODERATE to HIGH

Network Monitoring	None / Splunk SIEM 250GB/day ingest, 24/7
Endpoint Protection	Basic antivirus / Huntress MDR with auto-quarantine, 24/7 SOC
Incident Response Plan	None / Full IRT, P1-P5 severity matrix, biannual exercises
Security Awareness Training	None / KnowBe4 quarterly + monthly phishing simulations, 200 users
Identity Management	Basic AD, no MFA / Okta MFA 100% target, CyberArk PAM
Remote Access Security	None / Zscaler Zero Trust Exchange, ZTNA model
Threat Intelligence	None / CISA KEV, MITRE ATT&CK, CISA advisories
Vulnerability Management	None / Qualys VMDR, 500+ assets, KEV 48-hour SLA
Business Continuity Plan	None / Full BCP with GSL failover, 4-hour RTO, Austin relay hub
Cybersecurity Policies	None / 5 formal policies aligned to NIST CSF 2.0 and CIS Controls v8
Governance Framework	None / AZTOF CMP covering all 6 domains with Fayol management functions
Data Classification	None / 4-tier classification policy, DLP tooling, annual review
Ranked CSET Gaps	10 critical gaps at Low level / All 10 gaps closed and remediated

6. Assessment Limitations and Complementary Activities

The CSET self-assessment methodology has inherent limitations that are important to acknowledge. CSET evaluates whether controls are documented and implemented based on the assessor's responses to structured questions. It does not independently verify technical configurations, perform network scanning, or test the effectiveness of controls under actual attack conditions.

For ZOS, the CSET assessment was used as the framework-based starting point for this engagement. The following complementary activities were conducted or are planned to address areas that CSET cannot evaluate:

- Technical network analysis: Direct review of firewall configurations, VLAN segmentation, switch configurations, and wireless security settings was performed as part of the redesign process.
- Annual penetration testing: Qualys VMDR and annual third-party penetration testing provide the technical validation that CSET cannot. The penetration test will target the specific vulnerabilities and attack paths most relevant to ZOS ground station operations.
- Ongoing SIEM monitoring: Splunk continuous monitoring provides real-world validation that detection controls are functioning as designed.
- Tabletop exercises: Biannual IRT and BCP exercises test response and recovery capabilities in realistic scenarios including GSL failover and ransomware response.

A self-assessment with CSET cannot reveal all types of security weaknesses and should not be the sole means of determining ZOS's security posture. This narrative, the CSET tool reports, and the complementary technical activities together provide a comprehensive picture of the ZOS cybersecurity program.

7. Ongoing Recommendations and Next Steps

Based on the Assessment 1 and Assessment 2 results and the ZOS-specific operational context, the following ongoing recommendations are in place:

- Conduct Assessment 3 after the first full year of AZTOF program operation to measure maturity progression and identify any new gaps introduced by organizational or infrastructure changes.
- Execute the annual third-party penetration test targeting ZOS external attack surface, internal network segmentation, wireless networks, and the ZOS satellite data relay API.
- Complete the first biannual IRT tabletop exercise within 6 months of this assessment, including a simulated ransomware scenario that triggers Huntress auto-quarantine and tests the IRP P1-P5 response procedures.
- Complete the first Austin relay hub GSL failover test within 6 months to validate the 4-hour RTO established in the BCP.
- Target CISA ZTMM 2.0 Advanced maturity stage across all five pillars (Identity, Devices, Networks, Applications, Data) within 36 months of AZTOF program launch.
- Achieve 100% MFA enrollment across all 200 ZOS users within the first quarter of program operation.
- Complete CMMC Level 2 assessment preparation within 12 months to support ZOS defense client contract compliance obligations.

8. Conclusion

The two CSET assessments conducted for Zenith Orbital Systems in February 2026 document a clear and significant improvement in cybersecurity posture. Assessment 1 established a baseline of Low Security Assurance Level with ten critical ranked gaps across the Detect, Recover, Identify, and Protect functions of NIST CSF 2.0. Every one of those gaps directly threatened ZOS's ability to detect, respond to, and recover from a cyberattack affecting ground station operations.

Assessment 2 confirmed that the ZOS network redesign and the broader AZTOF cybersecurity program addressed all ten critical gaps with specific, implemented controls. The Security Assurance Level improved from Low to Moderate/High. The ZOS network now has detection capability through Splunk SIEM and Huntress MDR, response capability through the documented IRT and Incident Response Plan, recovery capability through the Business Continuity Plan with Ground-to-Space Link Redundancy, and governance capability through the AZTOF framework and five formal cybersecurity policies.

For ZOS, cybersecurity improvement is not an abstract metric. It is the difference between a ground station that can detect and respond to an attack before it reaches the satellite command systems and one that cannot. The CSET assessment results demonstrate that ZOS has made that transition. The ongoing recommendations in Section 7 define the path forward to continue improving that posture over time.

Assessment prepared by: Noe Valencia, Principal Systems Security Engineer (PSSE)

Organization: Zenith Orbital Systems (ZOS)

Assessment Dates: February 20, 2026 (Original Network) and February 23, 2026 (Redesigned Network)

Report Date: May 10, 2026

9. Sources and References

- CISA Cyber Security Evaluation Tool (CSET). <https://www.cisa.gov/resources-tools/services/cyber-security-evaluation-tool>
- NIST Cybersecurity Framework 2.0. February 26, 2024. <https://csrc.nist.gov/pubs/cswp/29>
- CISA Known Exploited Vulnerabilities (KEV) Catalog. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- CISA Zero Trust Maturity Model v2.0. April 2023. <https://www.cisa.gov/zero-trust-maturity-model>
- NIST SP 800-207: Zero Trust Architecture. 2020. <https://csrc.nist.gov/publications/detail/sp/800-207/final>
- Verizon. 2025 Data Breach Investigations Report (DBIR). 2025.
- IBM Security. Cost of a Data Breach Report 2024. 2024.
- MITRE ATT&CK Enterprise Framework. <https://attack.mitre.org>

Finance and Pricing

The budget below covers everything needed to build and operate a complete cybersecurity program for ZOS. All pricing reflects current market data for FY 2027. Eight categories cover hardware, software, services, and personnel.

1. Network Security Infrastructure

Item	Unit Cost	Qty	Initial Cost
Palo Alto PA-5220 NGFW (HA pair)	\$28,000	2	\$56,000
Cisco Catalyst 9300 L3 Core Switch	\$12,500	2	\$25,000
Cisco Catalyst 9200 L2 Access Switch	\$4,800	6	\$28,800
Cisco Meraki MR57 Wi-Fi 6E APs	\$2,100	12	\$25,200
Splunk Enterprise SIEM (250GB/day)	\$72,000/yr	1	\$72,000
Cisco SmartNet 24/7 Support (all switches)	\$1,000/dev/yr	8	\$8,000/yr
Cat6a Plenum cabling and installation	\$18,500	1	\$18,500
Subtotal			\$225,500

2. Endpoint Protection

Item	Unit Cost	Qty	Initial Cost
Huntress Managed EDR (200 endpoints)	\$7/ep/mo	200	\$16,800/yr
Dell Latitude 5550 Laptops	\$1,450	75	\$108,750

Dell OptiPlex 7010 Desktops	\$1,100	50	\$55,000
Dell PowerEdge R750 Servers	\$14,000	4	\$56,000
Dell 5-yr ProSupport Plus	\$250/dev	125	\$31,250
Subtotal			\$251,000

3. Identity and Access Management

Item	Unit Cost	Qty	Initial Cost
Okta Workforce Identity (200 users)	\$15/user/mo	200	\$36,000/yr
CyberArk PAM, Privileged Access Management	\$85,000/yr	1	\$85,000
Subtotal			\$121,000

4. Cloud Infrastructure and Security

Item	Unit Cost	Qty	Initial Cost
Microsoft 365 E5 (200 users)	\$57/user/mo	200	\$136,800/yr
Veeam Enterprise Plus Backup and DR	\$45,000/yr	1	\$45,000
MS Defender for Cloud (CASB)	Included in E5	N/A	\$0
Subtotal			\$136,800

5. Physical Security

Item	Unit Cost	Qty	Initial Cost
------	-----------	-----	--------------

Verkada Dome Cameras	\$1,200	20	\$24,000
Verkada Card Readers	\$850	10	\$8,500
Verkada Cloud License	\$2,400/yr	1	\$2,400/yr
Eaton UPS Rack Power Supply	\$3,695	2	\$7,390
Biometric Safe	\$400	1	\$400
Subtotal			\$40,290

6. Compliance and Risk Management

Item	Unit Cost	Qty	Initial Cost
Qualys VMDR, 500 assets	\$28,000/yr	1	\$28,000
Archer GRC Platform	\$40,000/yr	1	\$40,000
Annual Penetration Testing	\$25,000	1	\$25,000
Subtotal			\$93,000

7. Personnel and Training

Item	Unit Cost	Qty	Initial Cost
CISO / Security Director	\$185,000/yr	1	\$185,000
Senior Network Security Engineer	\$130,000/yr	2	\$260,000
Cybersecurity / SOC Analyst	\$95,000/yr	3	\$285,000
IT Systems Administrator	\$85,000/yr	2	\$170,000

KnowBe4 Security Awareness Training (200 users)	\$18,000/yr	1	\$18,000
Professional Certifications (CISSP, CEH, CompTIA)	\$5,000/person	8	\$40,000
Subtotal			\$958,000

8. Telecommunications and Connectivity

Item	Unit Cost	Qty	Initial Cost
AT&T Business Fiber, 10 Gbps dedicated	\$950/mo	1	\$11,400/yr
Zscaler Zero Trust Exchange (ZIA + ZPA, 200 users)	\$50/user/yr	200	\$10,000
GoDaddy SSL Wildcard and Domain Security	\$570/yr	1	\$570
Cisco IP Phones 8841 and 8831 Conference	varies	32	\$18,580
Subtotal			\$30,100

Professional Services and Implementation

Item	Unit Cost	Qty	Initial Cost
Network Architecture and Engineering (15 days)	\$3,500/day	15	\$52,500
Security Policy and Documentation Development	\$12,000	1	\$12,000

Hardware Installation and Rack Configuration (5 days)	\$2,200/day	5	\$11,000
Project Management (full lifecycle)	\$25,000	1	\$25,000
Contingency Reserve (5%)	N/A	N/A	\$25,750
Subtotal			\$126,250

Grand Total and Financing

Financial Summary	Amount
Project Subtotal (hardware, software, services, Year 1 personnel)	\$1,717,250.00
Estimated Sales Tax (8.25%, Texas state and local, Dallas)	\$141,673.00
GRAND TOTAL (with Tax)	\$1,858,923.00
40% Down Payment (required to initiate project)	\$743,569.00
Remaining Balance (due upon project completion and UAT)	\$1,115,354.00
Year 2 and Beyond, Annual Recurring Costs	\$383,200.00 / yr

Total Cost of Ownership Analysis

TCO is calculated based on a five-year lifespan for primary hardware assets divided across 200 supported users.

TCO = [Grand Total + (Annual Recurring x 4 years)] divided by 200 users divided by 5 years

TCO = [\$1,858,923 + (\$383,200 x 4)] divided by 200 divided by 5

TCO = \$3,391,723 divided by 1,000 user-years = \$3,391.72 per user per year

Over five years that comes out to about \$16,959 per user total. The average cost of a breach in aerospace and defense is over \$10 million. This program costs less than what a single incident would cost to clean up.

Cybersecurity Management Plan, AZTOF Framework

AZTOF is the management framework I built to govern all six security domains for ZOS. It stands for Adaptive Security and Zero Trust Operations Framework. It pulls from four standards: NIST CSF 2.0, NIST SP 800-207 Zero Trust Architecture, CISA Zero Trust Maturity Model 2.0, and MITRE ATT&CK Enterprise. Fayol's five management functions are applied across each domain to keep every area managed with clear ownership and measurable outcomes.

Framework Foundations

- NIST CSF 2.0: All six functions mapped across all AZTOF domains. The new Govern function is the organizational core.
- NIST SP 800-207 Zero Trust Architecture: ZTA seven tenets drive the IAG domain. No user or device is trusted by default.
- CISA Zero Trust Maturity Model 2.0: Used as the maturity assessment tool. ZOS targets the Advanced stage across all five pillars within 36 months.
- MITRE ATT&CK Enterprise: Used for threat modeling, detection gap analysis, and exercise design. SIEM rules are mapped to ATT&CK techniques.

Six AZTOF Domains Applied to ZOS

Domain 1, Identity and Access Governance (IAG): Okta MFA for all 200 users. CyberArk PAM for all privileged accounts. FIDO2 phishing-resistant authentication for high-privilege roles. Full identity lifecycle with under-four-hour deprovisioning SLA.

Domain 2, Threat Detection and Incident Response (TDIR): Splunk SIEM with 250GB/day ingest. Huntress Managed EDR with automatic endpoint quarantine. Virtual SOC with Huntress MDR covering Tier 2 and 3. IRP with P1 through P5 severity levels, P1 MTTR target under 30 minutes, P1 MTTR under 4 hours.

Domain 3, Data Protection and Privacy (DPP): AES-256 at rest, TLS 1.3 in transit. Four-tier data classification policy. DLP tooling deployed. Annual data discovery and privacy audits.

Domain 4, Vulnerability and Configuration Management (VCM): Qualys VMDR scanning all 500 assets. CISA KEV catalog monitored multiple times per week. Critical patch SLA of 48 hours for KEV-listed CVEs, 15 days for critical non-KEV.

Domain 5, Regulatory Compliance and Audit Readiness (RCAR): Archer GRC as the system of record. Compliance mapped to CMMC Level 2, NIST CSF 2.0, CIS Controls v8, and TDPSA. Annual third-party penetration test.

Domain 6, Security Culture and Workforce Resilience (SCWR): KnowBe4 quarterly training for all 200 ZOS personnel. Monthly phishing simulations. Biannual IRT tabletop exercises including at least one unannounced drill per year.

Policies in Place

ZOS has five formal cybersecurity policies in place. All five are based on SANS Institute templates, aligned to NIST CSF 2.0 and CIS Controls v8, effective March 28, 2026, and scheduled for annual review in March 2027. The policy framework received a score of 100% during course review.

1. General Password Protection Policy

This policy covers how passwords are created, managed, and protected across all ZOS systems. It sets minimum complexity requirements, prohibits password reuse, requires MFA for all privileged and remote access, and defines what happens when a password is compromised. It applies to every ZOS employee, contractor, and third-party service provider with system access.

2. Server Vulnerability Management Policy

This policy covers how ZOS identifies, prioritizes, and remediates vulnerabilities across all server infrastructure. SLA timeframes are tied to CISA KEV priorities: 48 hours for known exploited vulnerabilities, 15 days for critical non-KEV CVEs, and 30 days for high-severity findings. Quarterly Qualys VMDR scans and annual penetration testing are required. Consequences for policy violations are defined from written warning up to termination.

3. Network Device Management Policy

This policy covers configuration baselines, change control procedures, and access requirements for all ZOS network devices including firewalls, switches, WAPs, and routers. Zero Trust principles apply at the device layer: no default trust, least-privilege admin access, and all changes require documented authorization. Aligned to CIS Benchmarks and the NSA/CISA Zero Trust Implementation Guideline Primer from January 2026.

4. Application and Cloud Service Provider Management Policy

This policy governs how ZOS selects, onboards, monitors, and offboards cloud service providers and SaaS applications. Every new CSP requires a formal security assessment before onboarding. It maps to FedRAMP authorization requirements given our defense client obligations. It covers data residency, encryption standards, and breach notification SLAs for all cloud vendors across AWS, Azure, and GCP.

5. Cybersecurity Incident Response Plan

This document establishes the ZOS Incident Response Team structure, roles, responsibilities, and activation procedures. It defines six severity levels from 0 through 5 with corresponding activation levels and response timelines. Huntress MDR serves as the primary AI-powered detection and automated quarantine capability. Out-of-band

communication methods, information recording requirements, and post-incident review procedures are all documented. I serve as the Incident Response Manager, supported by Michael R. Torres as Director of Mission Assurance and Gregory A. Whitfield as Legal and Compliance Liaison.

Business Continuity Plan Summary

The ZOS Business Continuity Plan was built around Ground-to-Space Link Redundancy. If the Dallas ground station goes down, ZOS needs a tested, documented plan to maintain command and control of orbital assets through the Austin relay hub. A gap in ground-to-space link continuity is not a business continuity issue, it is a mission failure. That requirement drove every design decision in the BCP.

BCP Recovery Team, Zenith Orbital Systems

Name	ZOS Title	BCP Role
Michael R. Torres	Director of Mission Assurance and Continuity	Incident Commander
Daniel J. Kowalski	Ground Systems IT Manager	IT Recovery Lead
Sandra L. Pham	HR and Communications Director	HR / Public Information Officer
Rachel M. Okafor	Chief Financial Officer	Finance / Admin
Gregory A. Whitfield	General Counsel and Compliance Officer	Legal / Contracts
Lisa M. Cabrera	Dallas Ground Station Operations Lead	Business Function Leader
Kevin D. Nguyen	Austin Relay Hub Operations Lead	Business Function Leader, Austin Failover
Carlos E. Mendoza	Orbital Systems Security Analyst	Cybersecurity Monitor
James R. Holloway	Satellite Network Administrator	Network and Systems Recovery
Noe Valencia	Principal Systems Security Engineer	Security Recovery Coordinator

Recovery Phases

Phase I, Disaster Occurrence: Immediate damage assessment, personnel notification, and activation decision by Incident Commander Michael R. Torres.

Phase II, Plan Activation: IRT and BCP recovery team assembled at the Emergency Operations Center. Recovery strategy reviewed and adjusted based on available personnel. Critical staff directed to the Dallas alternate site or Austin relay hub as needed. Non-critical staff work remotely.

Phase III, Alternate Site Operations: If Dallas is non-operational, Kevin D. Nguyen activates Austin relay hub operations. Ground-to-space link continuity is maintained through Austin. All mission-critical satellite command functions transfer to Austin. Client communications are managed by Sandra L. Pham.

Phase IV, Return to Normal Operations: Dallas facility restored and validated. Systems and data verified against Veeam backup integrity checks before returning to primary operations. Full after-action review completed within five business days of recovery completion.

Incident Response Plan Summary

The ZOS Cybersecurity Incident Response Plan gives us a structured, repeatable process for detecting, containing, eradicating, and recovering from cybersecurity incidents. It defines the Incident Response Team, activation procedures, communication protocols, and post-incident review requirements.

Incident Response Team

Role	Assigned To	Primary Responsibilities
Head of IT / Incident Response Manager	Noe Valencia	Coordinate IRT, discover and verify incidents, direct technical remediation
Director of Mission Assurance	Michael R. Torres	Executive oversight, mission impact assessment, board communications
General Counsel and Compliance Officer	Gregory A. Whitfield	Legal notifications, regulatory compliance, law enforcement coordination
HR and Communications Director	Sandra L. Pham	Employee communications, data exposure notifications, public relations
Chief Financial Officer	Rachel M. Okafor	Financial impact assessment, authorize emergency expenditures
Orbital Systems Security Analyst	Carlos E. Mendoza	Technical analysis, threat hunting, containment support
MDR / AI Detection (Secondary)	Huntress	24/7 threat detection, automatic endpoint quarantine, forensic support

Severity Level Matrix

Level	Description	IRT Activation
5	Enterprise-wide attack, data exfiltration, systems inaccessible	Full Team Active, IRM and all IRT members

4	Group affected, elevated privilege compromise, sensitive data at risk	Full Team Informed and Advised
3	Single individual with significant sensitive data, PII may be involved	Primary Team Informed, Legal notified if PII
2	Group affected, no sensitive data involved	Primary Team Informed
1	Single individual, no sensitive data, correction and prevention focus	No IRT activation, IT coordinates
0	Very minor or undetermined, normal IT support process applicable	No activation, documented normally

The IRP includes a dedicated ransomware playbook for double-extortion scenarios, pre-established coordination protocols with the FBI Cyber Division and CISA, and biannual tabletop exercises including at least one unannounced drill per year. Post-incident reviews are required within five business days of all Level 4 and Level 5 incidents.

Conclusion

Zenith Orbital Systems has been trusted with the command and control of orbital assets for commercial and defense clients. That trust only holds if the ground infrastructure behind it is secure, resilient, and continuously monitored. This proposal delivers that.

Everything in this proposal was built from a real starting point. The CSET assessment identified exactly what was wrong with the original network, and every section of this document responds to a specific finding. The network was redesigned, the policies are written and validated, the continuity and incident response plans are documented with ZOS-specific requirements, and the budget was built with real pricing and a five-year analysis. The AZTOF framework ties everything together into a program that can be governed and audited.

The total investment is \$1,858,923.00. The average cost of a breach in aerospace and defense is over \$10 million. This program does not just reduce risk, it pays for itself in the breach it prevents.

Zenith Orbital Systems is in the business of keeping things in orbit. This proposal keeps us in business. I look forward to the board's approval and am ready to begin implementation the moment funding is authorized.

Respectfully submitted,

Noe Valencia

Principal Systems Security Engineer (PSSE)

Zenith Orbital Systems

May 10, 2026

1. Purpose Password Protection Policy

This Password Protection Policy establishes standards and guidelines for the creation, management, protection, and periodic assessment of passwords across all Zenith Orbital Systems (ZOS) systems and accounts. Compromised credentials remain the single leading cause of data breaches worldwide. According to the Verizon 2025 Data Breach Investigations Report, stolen, weak, or reused passwords are involved in 88% of basic web application attacks and 22% of all breaches. In 2025 alone, over 5 billion accounts were compromised globally.

This policy provides a clear, enforceable framework that enables ZOS personnel to create strong credentials, reduces the burden of password management through approved tooling, mandates multi-factor authentication, and establishes screening controls that prevent the use of known compromised passwords. By aligning with NIST SP 800-63B, Microsoft's modern authentication guidance, and current industry best practices, this policy protects ZOS mission assets without imposing unnecessary friction on users.

2. Scope

This policy applies to all employees, contractors, consultants, temporary workers, and third-party personnel with access to any ZOS system, account, or resource. It covers all password-protected accounts and credentials including:

- User-level accounts on all ZOS systems and platforms
- System-level and service accounts, including automated processes and scripts
- Web application and SaaS platform accounts
- Email and collaboration platform accounts
- Privileged and administrative accounts
- VPN, remote access, and network device accounts
- Voicemail, screen saver, and local device protection
- API keys, tokens, and other programmatic credentials

Compliance with this policy is mandatory for all in-scope individuals. Deviations require written approval through the exception process defined in Section 12.

3. Principle Statement

Password security at ZOS is managed on the principle that length is more important than complexity, usability supports compliance, and no password policy is complete without multi-factor authentication. Forcing users into rigid, frequently-changing complexity requirements has been shown by NIST and Microsoft research to produce weaker security outcomes because users respond with predictable patterns, minor variations, and credential reuse.

This policy reflects the modern consensus: require long passphrases over short complex strings, eliminate arbitrary expiration cycles, screen all passwords against known breach databases, mandate MFA on all sensitive systems, and use approved password managers to eliminate the human memory burden that drives poor credential hygiene.

4. Senior Management Commitment

ZOS senior leadership is fully committed to the implementation and enforcement of this Password Protection Policy. We recognize that credential compromise is the most common entry point for attackers and that protecting ZOS accounts and orbital mission systems requires both strong technical controls and a user-friendly approach that personnel will actually follow.

Senior management commits to providing approved password manager tools, MFA infrastructure, and training resources necessary to support compliance with this policy. This policy will be reviewed annually and updated to reflect changes in NIST guidance, industry standards, and the threat environment.

Signed: _____ **Date:** _____

Chief Information Security Officer / Senior IT Leadership, Zenith Orbital Systems

5. Industry Benchmarks and Current Trends (2026)

5.1 Length Over Complexity

The industry has decisively moved away from arbitrary complexity requirements toward length-based standards. In 2026, a standard consumer-grade GPU can crack an 8-character password in under 12 minutes regardless of its complexity. A 16-character passphrase composed of unrelated common words is exponentially harder to crack and far easier for users to remember. NIST, Microsoft, and the UK's National Cyber Security Centre all now recommend this approach.

5.2 Elimination of Mandatory Periodic Rotation

Mandatory 30, 60, or 90-day password rotation cycles are now recognized by NIST and Microsoft as counterproductive. Research consistently shows that users respond to forced rotation by making minimal changes to existing passwords, which provides no real security benefit. Both NIST SP 800-63B and Microsoft's current guidance recommend that passwords only be changed upon evidence or suspicion of compromise, not on a calendar schedule. This policy adopts that standard for standard user accounts while retaining annual rotation requirements for ZOS privileged accounts.

5.3 Breached Password Screening

Modern authentication systems now integrate with breach databases such as HaveIBeenPwned, which contains over 10 billion compromised credentials, to screen passwords at creation and login time. Specops Software's 2026 research found that predictable behavior such as uppercase first letters, numbers at the end, and common substitutions remains the dominant pattern in breached corporate credentials,

confirming that composition rules without breach screening provide a false sense of security.

5.4 MFA as the Primary Defense Layer

Multi-factor authentication has become the single most impactful control in the credential security stack. Microsoft's data shows that MFA prevents over 99.9% of credential-based account compromises. In 2026, the standard is moving toward number-matching MFA and phishing-resistant MFA such as FIDO2 hardware keys and passkeys, which eliminate the push notification attack surface entirely. ZOS targets FIDO2 authentication for all privileged roles per the AZTOF Identity and Access Governance domain.

5.5 Password Managers as Organizational Infrastructure

Enterprise-grade password managers such as 1Password Business and Bitwarden Teams have evolved from personal productivity tools into organizational security infrastructure. They generate cryptographically random passwords, eliminate credential reuse across systems, store credentials in encrypted vaults with access controls, and provide administrative visibility into credential health across the organization.

6. Roles and Responsibilities

Role	Primary Responsibilities
IT Security Manager	Policy owner; annual review; exception approvals; violation escalation; compliance reporting
Systems Administrators	Implement technical controls; configure account lockout; operate breach screening tools; enforce MFA enrollment
Security Analysts	Conduct quarterly password audits; review lockout logs; track policy compliance metrics
All ZOS Employees and Contractors	Create compliant passwords; enroll in MFA; use approved password manager; report suspected compromise immediately
New Hires	Complete password security training during onboarding; enroll in MFA on first day of access

7. Policy Controls and Standards

7.1 Password Length and Format

Control ID	Requirement
------------	-------------

PWD-01	Minimum password length is 16 characters. Systems must support passwords up to at least 64 characters to enable passphrase use.
PWD-02	Passphrases composed of multiple unrelated words are the preferred password format. Examples include metal-lemon-49-blanket or sunrise-cable-forest-rain. Predictable patterns such as ZOS2026 or seasonal passwords like Spring2026 are prohibited.
PWD-03	Passwords must not be reused across ZOS accounts. Users must not reuse any of their last 10 passwords on any given system.
PWD-04	Passwords must never be shared with any other person, including managers, IT staff, or help desk personnel. ZOS IT staff will never ask for a user's password.

7.2 Password Screening and Breach Detection

Control ID	Requirement
PWD-05	All new passwords must be screened against known-compromised credential databases at the time of creation. Passwords found in breach databases must be rejected regardless of length or complexity. HaveIBeenPwned API or equivalent is required.
PWD-06	The InfoSec Team will conduct periodic password audits using approved cracking tools to identify weak or guessable passwords on ZOS systems. Users whose passwords are identified as weak will be required to change them immediately.

7.3 Password Expiration and Rotation

Control ID	Requirement
PWD-07	Standard user account passwords do not require periodic rotation unless compromise is known or suspected. Password changes are required immediately upon any confirmed or suspected account compromise.

PWD-08	Privileged account passwords must be rotated at minimum annually. Service account passwords must be rotated whenever the responsible administrator leaves the organization or their role changes.
---------------	---

7.4 Multi-Factor Authentication (MFA)

Control ID	Requirement
PWD-09	MFA is mandatory for all ZOS accounts accessing email, collaboration platforms, VPN and remote access, cloud services, administrative and privileged accounts, and any system containing sensitive or regulated data.
PWD-10	Approved MFA methods in order of preference: FIDO2 hardware keys or passkeys (required for all privileged roles); authenticator app with number matching (Okta Verify, Microsoft Authenticator); push notification with number matching. SMS-based MFA is not permitted for any ZOS account.

7.5 Password Management Tools

Control ID	Requirement
PWD-11	All ZOS personnel must use only approved enterprise password manager tools for storing organizational credentials. Personal consumer-grade password managers are not permitted for organizational credentials. The approved ZOS password manager is provisioned and managed by the IT Security Team.
PWD-12	Passwords must never be stored in plaintext in documents, spreadsheets, email, messaging apps, code repositories, or any other unencrypted format. All stored passwords must use approved hashing algorithms (bcrypt, Argon2id, or PBKDF2 with minimum recommended iterations). This control protects credentials even if the underlying database is breached.

7.6 Account Lockout

Control ID	Requirement
-------------------	-------------

PWD-13	Account lockout must be enforced after no more than 10 consecutive failed login attempts. Lockout duration must be at minimum 15 minutes or until reset by IT. Lockout events must be logged and reviewed for patterns indicating brute force attacks.
---------------	--

8. Legal and Regulatory Obligations

Framework	Relevance to This Policy
NIST SP 800-63B	Primary technical standard for password length, complexity, screening, expiration, and MFA requirements
NIST CSF 2.0	Protect (PR.AC) function: Identity management, authentication, and access control
CIS Controls v8	Control 5 (Account Management), Control 6 (Access Control Management): password and MFA requirements
PCI DSS v4.0	Requirements 8.2 and 8.3: minimum 12-character passwords, MFA for admin and remote access, account lockout after 10 attempts
ISO/IEC 27001:2022	Annex A.9 (Access Control): authentication management, password policies, privileged access
HIPAA Security Rule	Administrative and technical safeguards requiring unique user identification and authentication controls
GDPR and TDP SA	Appropriate technical measures to protect personal data, including strong authentication for systems processing personal information

9. Training and Awareness

All ZOS personnel must receive password security training appropriate to their role:

- All Employees and Contractors: Annual training on passphrase creation, the approved password manager, MFA enrollment and use, recognizing phishing and credential theft attempts, and the procedure for reporting suspected account compromise.
- System Administrators: Annual training on implementing and enforcing technical password controls in Active Directory and all platforms, configuring account lockout policies, and operating breach screening tools.

- New Hires: Password security training must be completed during onboarding, prior to receiving access credentials. MFA enrollment must be completed on the first day of access.

Training completion records are maintained by the IT Security Team and retained for a minimum of three years.

10. Compliance Measurement

Activity	Controls Assessed / Frequency
Password audit using approved cracking tools	PWD-05, PWD-06 / Quarterly
Breached password screening report review	PWD-05 / Monthly (automated)
MFA enrollment verification	PWD-09, PWD-10 / Monthly
Account lockout event log review	PWD-13 / Weekly
Privileged account password rotation audit	PWD-08 / Annual
Password manager adoption report	PWD-11 / Quarterly
Full policy compliance assessment	All PWD controls / Annual

Results are documented and reported to the IT Security Manager. Material non-compliance findings are escalated to senior IT leadership within 5 business days.

11. Exception Management

Legacy systems or operational constraints may occasionally prevent full compliance with specific controls. All exceptions must follow this process:

- The requesting party submits a written exception request to the IT Security Manager documenting the specific control affected, the technical or business justification, proposed compensating controls, and the requested duration (maximum 90 days).
- Exceptions to PWD-09 (MFA requirement) require both IT Security Manager and senior IT leadership approval given the elevated risk of unauthenticated access.

- All approved exceptions are logged in the exception register with compensating controls, approving authority, and expiration date.
- The exception register is reviewed monthly. Expired exceptions not formally renewed are treated as policy violations.

12. Policy Sanctions

Non-compliance with this policy will result in disciplinary action consistent with ZOS human resources policies. Sanctions are applied consistently and proportionally:

Severity	Consequence
Minor / First Offense	Formal written warning; mandatory remedial training; re-acknowledgment of policy required within 10 business days
Moderate / Negligent	Formal written warning; mandatory remedial training; review with IT Security Manager; potential temporary suspension of elevated access
Severe / Willful Violation	Immediate review of system access; HR investigation; potential removal of administrative access; potential termination of employment or contract
Criminal / Illegal Activity	All above consequences plus referral to law enforcement; legal action under applicable federal and state statutes

13. Sources and References

- NIST SP 800-63B Digital Identity Guidelines. <https://pages.nist.gov/800-63-3/sp800-63b.html>
- NIST Cybersecurity Framework 2.0. <https://www.nist.gov/cyberframework>
- CIS Controls v8. <https://www.cisecurity.org/controls/v8>
- PCI DSS v4.0. https://www.pcisecuritystandards.org/document_library/
- ISO/IEC 27001:2022. <https://www.iso.org/standard/82875.html>
- CISA Known Exploited Vulnerabilities Catalog. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- Verizon 2025 Data Breach Investigations Report. <https://www.verizon.com/business/resources/reports/dbir/>
- Microsoft Password Guidance. <https://www.microsoft.com/en-us/research/publication/password-guidance/>
- SANS Institute Security Policy Templates. <https://www.sans.org/information-security-policy/>

ZENITH ORBITAL SYSTEMS

Server Vulnerability Management Policy

Effective: March 28, 2026 | Next Review: March 2027 | Version 1.0

Prepared by: Noe Valencia, PSSE

1. Purpose

This Vulnerability Management Policy establishes a comprehensive, risk-based framework for identifying, prioritizing, remediating, and tracking vulnerabilities across all Zenith Orbital Systems (ZOS) server infrastructure, endpoints, and network devices. Unpatched vulnerabilities are consistently among the most preventable and most exploited attack vectors. The 2025 Verizon DBIR identified vulnerability exploitation as the initial access vector in 20% of all breaches analyzed, and the CISA KEV catalog grew by 245 confirmed-exploited vulnerabilities in 2025 alone.

For ZOS, which operates ground station infrastructure supporting orbital asset command and control, a successful exploitation of an unpatched vulnerability could result in loss of satellite command capability. This policy is built around that operational reality.

2. Scope

This policy applies to all ZOS personnel who administer, maintain, or interact with any in-scope system. In-scope systems include:

- All ZOS server infrastructure (physical and virtual) including domain controllers, file servers, application servers, VoIP servers, and backup systems
- All ZOS endpoint devices including workstations, laptops, and mobile devices enrolled in ZOS management
- All ZOS network devices including firewalls, switches, routers, and wireless access points
- All ZOS cloud-hosted systems and virtual machines
- All third-party systems with network connectivity to ZOS infrastructure

Compliance with this policy is mandatory for all in-scope individuals. Deviations require written approval per Section 12.

3. Principle Statement

Vulnerability management at ZOS operates on the principle of continuous, risk-based prioritization. Not all vulnerabilities pose equal risk. CISA's Known Exploited Vulnerabilities catalog, CVSS scoring, and ZOS-specific operational context together determine remediation priority. Speed matters: the median time from vulnerability disclosure to exploitation in the wild dropped to under 5 days in 2025. ZOS remediation SLAs are calibrated to that reality.

4. Senior Management Commitment

ZOS senior leadership is fully committed to the implementation and enforcement of this Vulnerability Management Policy. We recognize that unpatched server and system vulnerabilities are among the most preventable and consistently exploited entry points for ransomware, data breaches, and unauthorized access. We commit to providing the scanning tools, remediation resources, and organizational authority required to manage vulnerabilities effectively.

Signed: _____ **Date:** _____
Chief Information Security Officer / Senior IT Leadership, Zenith Orbital Systems

5. Roles and Responsibilities

Role	Primary Responsibilities
IT Security Manager	Policy owner; oversees VM system operation; sets remediation SLAs; approves exceptions; escalates unresolved critical vulnerabilities to leadership
Systems Administrator	Deploys and maintains scanning agents; remediates identified vulnerabilities per SLA; implements configuration fixes for CCE findings; coordinates with change management
Security Analyst	Reviews scan results; validates prioritization; investigates anomalies; produces technical and business reporting; tracks open vulnerability aging
IT Manager	Receives business unit vulnerability reports; ensures remediation resources are allocated; approves emergency patching outside normal change windows
Business Leadership	Receives executive vulnerability posture reports; provides organizational authority for resource allocation to address critical unresolved vulnerabilities
All Staff	Must not interfere with vulnerability scanning agents; must report suspected system compromises immediately to the IT Security Manager

6. Policy Safeguards

6.1 Vulnerability Management System and Scanning

Control ID	Requirement
VUL-01	Deploy an enterprise-grade vulnerability management system (Qualys VMDR) with authenticated scanning agents on all in-scope systems. Unauthenticated scanning alone is insufficient and does not satisfy this control.
VUL-02	All in-scope systems must be enrolled in the VM system. Coverage must be verified monthly. Any newly deployed system must be enrolled within 5 business days of deployment.
VUL-03	Vulnerability scans must be performed at minimum weekly for all in-scope systems. Systems identified as high-risk or previously compromised may be scanned more frequently at the IT Security Manager's direction.
VUL-04	All scans must be authenticated using valid credentials with sufficient privilege to perform a complete system audit. Scan credentials must be managed within the approved PAM system (CyberArk) and rotated per the password policy.
VUL-05	Scan results must be retained for a minimum of 12 months to support trend analysis, compliance reporting, and forensic investigations.

6.2 Vulnerability Prioritization and Remediation SLAs

Control ID	Requirement
VUL-06	All identified vulnerabilities must be prioritized using CVSS score and CISA KEV catalog status. Remediation SLAs are defined as follows: Critical (CVSS 9.0 to 10.0 or KEV listed) 15 days for internet-facing systems and 30 days for internal systems. High (CVSS 7.0 to 8.9) 30 days. Medium (CVSS 4.0 to 6.9) 90 days. Low (CVSS below 4.0) 180 days or next scheduled maintenance.
VUL-07	The VM system must compare consecutive scan results to track remediation progress over time, identifying newly discovered vulnerabilities, successfully remediated items, and vulnerabilities that have aged beyond their remediation SLA.

VUL-08	The VM system must maintain a continuously updated register of all open vulnerabilities including their severity, affected system, assigned owner, discovery date, SLA deadline, and current remediation status.
---------------	--

6.3 Exception Tracking and Reporting

Control ID	Requirement
VUL-09	The VM system must track all approved vulnerability exceptions including the CVE or CCE identifier, affected system, business justification, compensating controls in place, approving authority, and exception expiration date. Exceptions must be reviewed at minimum quarterly.
VUL-10	Technical vulnerability reports for Security Analysts and Systems Administrators must be generated at minimum weekly and include newly discovered vulnerabilities, SLA status for open items, scan coverage metrics, and remediation trend data.
VUL-11	Business unit vulnerability reports summarizing open vulnerabilities affecting systems supporting their functions, expressed in business impact terms, must be generated at minimum monthly.
VUL-12	Executive vulnerability posture reports for ZOS leadership must include overall vulnerability trend metrics, SLA compliance rates, critical open vulnerability counts, and risk posture summary expressed in business risk terms. Generated at minimum monthly.

7. Remediation SLA Summary

Severity / CVSS Range	Internet-Facing SLA / Internal System SLA
Critical or KEV Listed (CVSS 9.0 to 10.0)	15 days / 30 days
High (CVSS 7.0 to 8.9)	30 days / 30 days
Medium (CVSS 4.0 to 6.9)	90 days / 90 days

Low (CVSS below 4.0)	180 days / Next maintenance window
----------------------	------------------------------------

Vulnerabilities listed in the CISA Known Exploited Vulnerabilities (KEV) catalog are treated as Critical regardless of their CVSS score, due to confirmed active exploitation. The IT Security Manager may escalate SLA timeframes for any vulnerability based on active threat intelligence.

8. Penetration Testing

Vulnerability scanning identifies known vulnerabilities based on CVE and CCE databases. Penetration testing goes further by attempting to chain and exploit vulnerabilities to determine actual exploitability and impact in the specific ZOS environment. ZOS requires both: continuous scanning for known vulnerabilities and periodic penetration testing to validate that the vulnerability management program is actually reducing risk.

- Annual penetration testing by a qualified third-party firm is required at minimum.
- The penetration test scope must include ZOS external attack surface, internal network segmentation, wireless networks, and social engineering components.
- All penetration test findings must be remediated per the standard SLA timeframes, with critical findings tracked by the IT Security Manager to completion.
- Penetration test reports must be retained for a minimum of three years.

9. Legal and Regulatory Obligations

Framework	Relevance to This Policy
NIST SP 800-40 Rev 4	Defines patch management program requirements including scan frequency, remediation SLAs, and exception handling
NIST SP 800-53 Rev 5	SI-2 (Flaw Remediation), RA-5 (Vulnerability Scanning), SI-6 (Security Function Verification)
NIST CSF 2.0	Identify (ID.RA) and Protect (PR.IP) functions: vulnerability assessment and remediation
CIS Controls v8	Control 7 (Continuous Vulnerability Management): scanning, prioritization, remediation, and reporting requirements
CISA Binding Operational Directive 22-01	KEV catalog remediation mandates adopted as industry best practice for prioritization

PCI DSS v4.0	Requirements 6.2, 6.3, 11.3: vulnerability scanning, penetration testing, and remediation SLAs
ISO/IEC 27001:2022	Annex A.8.8 (Management of technical vulnerabilities): scanning, assessment, and remediation requirements

10. Training and Awareness

- Systems Administrators: Annual training on VM system operation, authenticated scan configuration, CVE and CCE remediation procedures, and emergency patching protocols.
- Security Analysts: Ongoing training on vulnerability prioritization frameworks including KEV catalog and EPSS scoring, vulnerability report generation, and trend analysis.
- Business Unit Staff and Leadership: Annual training on interpreting vulnerability posture reports and their responsibilities in supporting timely remediation.

11. Compliance Measurement

Activity	Controls Assessed / Frequency
Full authenticated vulnerability scan	VUL-01 through VUL-05 / Weekly
Scan coverage verification	VUL-01, VUL-02 / Monthly
Remediation SLA compliance review	VUL-06, VUL-07, VUL-08 / Weekly
Exception register review	VUL-09 / Quarterly
Annual penetration test	All controls validation / Annual
Executive posture report review	VUL-12 / Monthly

12. Exception Management and Policy Sanctions

All exceptions to remediation SLAs must be submitted in writing to the IT Security Manager with documented business justification, proposed compensating controls, and maximum 90-day duration. Critical and KEV-listed vulnerability exceptions require additional IT leadership approval.

Non-compliance sanctions follow the same structure as the Password Protection Policy, ranging from formal written warning for minor violations to termination and law enforcement referral for willful violations or criminal activity.

13. Continual Improvement

This policy is reviewed at minimum annually. Earlier review is triggered by: a security incident involving an unpatched vulnerability or configuration weakness; addition of a new system category or major infrastructure change; material updates to CISA KEV catalog priorities, NIST guidance, or CIS Controls; changes to applicable regulatory requirements; or findings from penetration testing identifying gaps in this policy's controls.

14. Sources and References

- SANS/CRF Vulnerability Management Policy Template (Feb 2026). <https://www.sans.org/information-security-policy/vulnerability-management-policy>
- CIS Controls v8, Control 7. <https://www.cisecurity.org/controls/v8>
- NIST SP 800-40 Rev 4. <https://csrc.nist.gov/publications/detail/sp/800-40/rev-4/final>
- NIST SP 800-53 Rev 5. <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>
- CISA KEV Catalog. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- CISA Binding Operational Directive 22-01. <https://www.cisa.gov/binding-operational-directive-22-01>
- PCI DSS v4.0. https://www.pcisecuritystandards.org/document_library/

ZENITH ORBITAL SYSTEMS

Network Device Management Policy

Effective: March 28, 2026 | Next Review: March 2027 | Version 1.0

Prepared by: Noe Valencia, PSSE

1. Purpose

This Network Device Management Policy establishes a comprehensive, enforceable framework for the secure configuration, monitoring, and lifecycle management of all network devices within Zenith Orbital Systems. Network devices including routers, switches, firewalls, and wireless access points form the critical backbone of ZOS IT infrastructure and the ground station network supporting orbital asset command and control. Their compromise directly threatens the confidentiality, integrity, and availability of every system and mission they support.

This policy implements controls aligned to the SANS/CRF Cybersecurity Policy Template (February 2026), CIS Benchmarks, NIST frameworks, and current industry best practices. By enforcing secure configurations, structured patch management, privileged access controls, and continuous monitoring, this policy seeks to minimize the risk of unauthorized access, data breaches, and network disruptions.

2. Scope

This policy applies to all ZOS employees, contractors, vendors, and third parties who administer, configure, access, monitor, or otherwise interact with network devices owned, leased, or operated by ZOS. It covers:

- Routers and Layer 3 switching equipment
- Layer 2 switches and managed network infrastructure
- Firewalls, next-generation firewalls (NGFW), and UTM appliances
- Wireless access points, WLAN controllers, and wireless infrastructure
- Virtual network devices, software-defined networking (SDN), and SD-WAN components
- Network management, monitoring, and IPAM systems
- Any device that performs network routing, switching, or security filtering functions

3. Principle Statement

Network device security at ZOS is managed on the principle of least privilege and Zero Trust. No device, user, or system is inherently trusted, and every access request to a network device must be continuously verified regardless of origin. This policy operates under the assumption that the network may be compromised at any time, requiring persistent authentication, authorization, and monitoring at every administrative access point.

4. Senior Management Commitment

ZOS leadership is fully committed to the implementation and ongoing enforcement of this Network Device Management Policy. We recognize that our network devices represent critical infrastructure assets whose compromise could result in significant operational, financial, reputational, and legal harm to ZOS and the defense and commercial clients we serve.

Signed: _____ **Date:** _____
Chief Information Security Officer / Senior IT Leadership, Zenith Orbital Systems

5. Roles and Responsibilities

Role	Primary Responsibilities
IT Security Manager	Policy owner; annual review; exception approvals; violation escalation; compliance reporting to leadership
Network Administrator	Implements all NDM controls; maintains device inventory; performs configuration management, patching, and change management
IT Manager	Ensures resource allocation; approves infrastructure changes; reviews exceptions with Security Manager
Security Analyst	Monitors NMS alerts; reviews netflow and log reports; conducts compliance assessments; escalates anomalies
All Staff and Contractors	Must not connect unauthorized devices; must immediately report suspected violations to IT Security Manager

6. Policy Safeguards

6.1 Inventory and Configuration Management

Control ID	Requirement
NDM-01	Maintain a complete, current inventory of all approved ZOS network devices, including make, model, firmware version, physical location, and assigned administrator.
NDM-02	Maintain documented cybersecurity configuration benchmarks aligned to the current CIS Benchmarks for

NDM-13	all authorized ZOS network device types. Benchmarks must be updated within 30 days of any material CIS Benchmark update.
	Use the network management system to perform regular automated comparisons of each device's live configuration against its approved baseline, logging and alerting on any detected changes. Configuration drift alerts must be investigated within 24 hours.

6.2 Secure Management Access

Control ID	Requirement
NDM-03	Manage all ZOS network devices exclusively from a dedicated, approved out-of-band management network subnet, isolated from the production network.
NDM-04	Prohibit management of network devices from any remote or Internet-based network without explicit, time-limited exception approval from the IT Security Manager.
NDM-05	Require that all network device management access is conducted through the approved Privileged Account Management (PAM) system (CyberArk) or dedicated management jump box with full session recording.
NDM-06	Require multi-factor authentication for all administrative access to network devices. Single-factor authentication is not permitted for any device management interface.
NDM-07	Prohibit all unencrypted management protocols. Telnet, HTTP, and SNMPv1/v2c are explicitly banned from all ZOS network devices. Only SSH v2, HTTPS, and SNMPv3 with authentication and encryption are permitted.

6.3 Monitoring and Logging

Control ID	Requirement
NDM-08	Deploy a centralized Network Management System (NMS) or SIEM integration capable of receiving syslog, SNMP traps, and configuration change alerts from all in-scope network devices.

NDM-09	Conduct automated vulnerability scans against all network devices at minimum monthly, using authenticated scanning where possible.
NDM-10	Configure real-time alerting for all critical events including: failed authentication attempts, configuration changes, device unreachability, interface flaps, and CPU or memory threshold breaches.
NDM-11	Retain all network device logs for a minimum of 90 days in the SIEM (Splunk) and 12 months in cold storage. Log integrity must be protected against modification.
NDM-12	Configure all ZOS network devices to export netflow data to the NMS or Splunk SIEM. Retain netflow records for a minimum of 90 days. Netflow analysis enables detection of anomalous traffic, lateral movement, and command-and-control communications.

6.4 Firmware and Lifecycle Management

Control ID	Requirement
NDM-14	Ensure all ZOS network devices operate on the latest vendor-supported firmware version. Patch critical and high severity vulnerabilities within 30 days and medium severity within 90 days. End-of-life devices must be decommissioned per an approved timeline.
NDM-15	All firmware updates must go through the ZOS change management process before deployment to production devices. Emergency patching procedures are pre-approved for CISA KEV-listed vulnerabilities.

6.5 Change Management

All changes to ZOS network device configurations must follow the formal change management process: documented change request, peer review by a second Network Administrator, IT Security Manager approval for high-risk changes, tested in a non-production environment where feasible, implemented during approved maintenance windows, and verified post-implementation with a baseline comparison scan.

7. Legal and Regulatory Obligations

Framework	Relevance
NIST CSF 2.0	Protect (PR) and Detect (DE) functions: secure configuration, access control, continuous monitoring
NIST SP 800-53 Rev 5	SC (System and Communications Protection), CM (Configuration Management), AU (Audit and Accountability)
NIST SP 800-207 Zero Trust Architecture	Mandates continuous verification for all device access; underpins NDM-03 through NDM-07
CIS Controls v8	Controls 1, 4, 5, 8, 12: asset inventory, secure configuration, account management, audit logs, network infrastructure
ISO/IEC 27001:2022	Annex A: Network security (A.8.20), Logging (A.8.15), Secure administration (A.8.31), Change management (A.8.32)
DISA Network Device STIGs	Federal baseline hardening requirements for routers, switches, and firewalls; aligns with NDM-02 and NDM-07

8. Continual Improvement and Sources

This policy is reviewed at minimum annually. Earlier review is triggered by material changes to CIS Benchmarks, NIST guidance, or the ZOS network architecture; a security incident involving a network device; or significant new vulnerabilities affecting ZOS device types.

- SANS/CRF Network Device Management Policy Template (Feb 2026). <https://www.sans.org/information-security-policy/network-device-management-policy>
- CIS Controls v8 and Benchmarks. <https://www.cisecurity.org>
- NIST SP 800-53 Rev 5, SP 800-207, SP 800-128. <https://csrc.nist.gov>
- NSA/CISA Zero Trust Implementation Guideline Primer (Jan 2026)
- CISA Zero Trust Maturity Model v2. <https://www.cisa.gov/zero-trust-maturity-model>
- DISA Network Device STIGs. <https://public.cyber.mil/stigs/>

ZENITH ORBITAL SYSTEMS

Cloud Service Provider Management Policy

Effective: March 28, 2026 | Next Review: March 2027 | Version 1.0

Prepared by: Noe Valencia, PSSE

1. Purpose

This Cloud Service Provider Management Policy establishes standards and requirements for the selection, onboarding, security assessment, ongoing monitoring, and offboarding of all cloud service providers (CSPs) and SaaS applications used by Zenith Orbital Systems. ZOS relies on cloud infrastructure for satellite data relay operations, mission telemetry backup, collaboration, and administrative functions. The security of those cloud environments is directly connected to ZOS mission assurance.

This policy ensures that all cloud services used by ZOS meet defined security standards before onboarding, maintain those standards throughout the relationship, and are securely offboarded when no longer required. It aligns to the SANS/CRF CSP Management Policy Template (February 2026), CIS Controls v8, NIST CSF 2.0, and FedRAMP authorization requirements relevant to ZOS defense client obligations.

2. Scope

This policy applies to all ZOS personnel responsible for selecting, contracting, managing, or using cloud services. It covers all cloud deployment models and service types:

- Infrastructure as a Service (IaaS): AWS, Azure, GCP, and other cloud hosting environments
- Platform as a Service (PaaS): Cloud databases, development platforms, container services
- Software as a Service (SaaS): Microsoft 365, Splunk Cloud, Okta, CyberArk, Huntress, KnowBe4, Qualys, Archer, Zscaler, and all other subscription software services
- Any third-party managed service that stores, processes, or transmits ZOS data

3. Principle Statement

ZOS treats cloud service providers as extensions of the ZOS security perimeter. No CSP is trusted by default. Every provider must demonstrate security capability before accessing ZOS data, and that capability must be continuously validated throughout the relationship. The responsibility for ZOS data never transfers to a CSP; ZOS retains accountability for data protection regardless of where data resides.

4. Senior Management Commitment

Signed: _____ Date: _____

Chief Information Security Officer / Senior IT Leadership, Zenith Orbital Systems

5. CSP Onboarding Requirements

No new cloud service provider may be onboarded to ZOS systems without completing the following steps:

- 1. Formal security assessment of the prospective CSP using the ZOS vendor security questionnaire. The assessment must evaluate: SOC 2 Type II certification status; encryption standards for data in transit and at rest; incident response and breach notification SLAs; data residency and sovereignty requirements; subprocessor disclosure and management; penetration testing history; and compliance certifications relevant to ZOS obligations (FedRAMP, ISO 27001, CMMC).
- 2. IT Security Manager review and written approval of the security assessment findings.
- 3. Legal review and execution of a Data Processing Agreement (DPA) or equivalent contractual instrument defining data handling obligations, breach notification requirements (72 hours maximum), and ZOS audit rights.
- 4. Documentation of the CSP in the ZOS cloud service inventory with designated business owner, data classification of data shared, and next review date.
- 5. Technical onboarding including SSO integration with Okta, MFA enforcement verification, API key management via approved PAM system, and CASB integration where applicable.

6. Ongoing CSP Monitoring Requirements

Control ID	Requirement
CSP-01	Maintain a complete, current inventory of all authorized ZOS cloud services including provider name, service type, data classification, business owner, contract expiration, and certification status.
CSP-02	Review the security posture of all Tier 1 CSPs (those handling sensitive or mission-critical ZOS data) at minimum annually. Reviews must include updated SOC 2 reports, security certification renewals, and vendor-provided breach history disclosures.
CSP-03	Monitor CSP security advisories, breach disclosures, and relevant threat intelligence feeds. Any CSP breach or

CSP-04	security incident affecting ZOS data must trigger immediate notification to the IRT and initiation of the Incident Response Plan. Enforce ZOS identity standards on all CSP platforms: Okta SSO integration required where technically feasible; MFA mandatory for all ZOS user accounts; FIDO2 authentication required for all privileged access; Zscaler CASB applied to monitor and control cloud application usage.
CSP-05	Verify that all ZOS data stored in CSP environments is encrypted at rest using AES-256 and in transit using TLS 1.3. Encryption key management must ensure ZOS retains control of encryption keys for sensitive data.

7. Data Classification and CSP Tier Assignment

ZOS Data Classification	CSP Tier
Mission Critical (satellite command and telemetry data)	Tier 1
Confidential (personnel data, financial data, client contracts)	Tier 1
Internal (general business operations)	Tier 2
Public (marketing content, public-facing websites)	Tier 3

8. CSP Offboarding Requirements

When a cloud service relationship is terminated, the following steps must be completed before contract expiration:

- Certified data deletion or data retrieval confirmation from the CSP covering all ZOS data including backups, logs, and derived data.
- Revocation of all ZOS user accounts, API keys, and integration credentials on the CSP platform.
- Removal of the CSP from the Okta SSO configuration and Zscaler CASB policy.

- Documentation of offboarding completion in the cloud service inventory, including the date of data deletion certification.
- Legal review to confirm all DPA obligations have been fulfilled by the CSP.

9. Legal and Regulatory Obligations

Framework	Relevance
NIST SP 800-53 Rev 5	SA-9 (External System Services), SA-12 (Supply Chain Risk Management)
NIST CSF 2.0	Govern (GV.SC) Supply Chain Risk Management; Protect (PR.AC) Access Control
FedRAMP Authorization Framework	Required for CSPs handling data related to ZOS defense client obligations
CIS Controls v8	Control 3 (Data Protection), Control 16 (Application Software Security)
ISO/IEC 27001:2022	Annex A.5.19 (Information security in supplier relationships)
GDPR and TDP SA	Data processor requirements for any CSP processing personal data of ZOS employees or clients
CMMC Level 2	Supply chain risk management practices for defense contractor obligations

10. Sources and References

- SANS/CRF Cloud Service Provider Management Policy Template (Feb 2026). <https://www.sans.org/information-security-policy/cloud-service-provider-management-policy>
- CIS Controls v8. <https://www.cisecurity.org/controls/v8>
- NIST SP 800-53 Rev 5. <https://csrc.nist.gov>
- NIST CSF 2.0. <https://www.nist.gov/cyberframework>
- FedRAMP Authorization Framework. <https://www.fedramp.gov>
- ISO/IEC 27001:2022. <https://www.iso.org/standard/82875.html>
- Flexera 2025 State of the Cloud Report. <https://www.flexera.com>

ZENITH ORBITAL SYSTEMS

Cybersecurity Incident Response Plan

Effective: March 22, 2026 | Next Review: March 2027 | Version 1.0

Prepared by: Noe Valencia, PSSE

Derived from SANS Institute Cybersecurity Sample Policies and Public Domain Sources

1. Goals for Cyber Incident Response

When a cybersecurity incident occurs, timely and thorough action to manage its impact is critical to an effective response. The response must limit potential damage by ensuring actions are well known, coordinated, and executed consistently. The goals of this plan are:

1. Preserve and protect the confidentiality of employee and constituent information, and ensure the integrity and availability of all ZOS organizational systems, networks, and data.
2. Help ZOS personnel recover their business processes following a computer or network security incident or data breach.
3. Provide a consistent, repeatable response strategy to system and network threats that put ZOS data and systems at risk.
4. Develop and activate a communications plan including initial reporting of the incident and ongoing communications as necessary throughout the response lifecycle.
5. Address cyber-related legal issues including regulatory notification obligations, contractual requirements, and potential law enforcement engagement.
6. Coordinate efforts with external Computer Incident Response Teams, forensic vendors, and law enforcement as appropriate.
7. Minimize ZOS reputational risk through controlled, timely, and accurate communications.

2. Purpose and Scope

This plan provides practical guidelines for responding to cybersecurity and data breach incidents in a consistent and effective manner. It establishes a team of first responders known as the Incident Response Team (IRT), with defined roles, responsibilities, and communication protocols.

While this plan is primarily oriented around cyber-related incidents and breaches, it may also be utilized for data breaches not directly related to computer systems, such as physical theft of records or inadvertent disclosure of printed materials.

This plan applies to all ZOS personnel, systems, and data. All employees, contractors, and third-party service providers with access to ZOS organizational systems are subject to this plan and must cooperate fully with the IRT during an active incident.

3. Incident Response Team (IRT)

A team comprised of ZOS staff, advisors, and service providers shall be responsible for coordinating incident responses. The IRT shall consist of both primary and secondary members. Primary members act as first responders and are engaged based on the severity of the incident. The entire team is activated for the most severe incidents.

There shall be a designated Incident Response Manager (IRM) who takes on organizational and coordination leadership of the IRT during an active incident. The IRM serves as the single point of coordination for all response activities. IRT members may take on additional roles during an incident as needed.

The IRT will draw upon Subject Matter Experts (SMEs) including IT staff, forensic vendors, legal counsel, and public relations advisors as required. Huntress serves as ZOS's AI-powered managed detection and response (MDR) provider and is a key SME for technical analysis, threat hunting, and initial containment guidance. When a threat is detected, Huntress AI automatically isolates the affected endpoint from the network, preventing the threat from spreading laterally to other systems or causing further damage while the IRT coordinates its full response.

3.1 Primary IRT Members

Role / Assigned To	Primary Responsibilities
Head of IT / IRM: Noe Valencia	Discover and verify incidents; notify IRT; coordinate forensic and technical remediation; apply corrective actions to infrastructure; maintain proactive cybersecurity posture; serve as single point of coordination during active incidents
Director of Mission Assurance: Michael R. Torres	Executive oversight of all incident response activities; mission impact assessment; board and client communications during severe incidents
General Counsel: Gregory A. Whitfield	Legal advisor; regulatory compliance; contractual matters; law enforcement liaison; PII breach notification obligations
HR and Communications Director: Sandra L. Pham	Manage public relations, news media, and all external and internal communications during an incident; employee data exposure notifications
Chief Financial Officer: Rachel M. Okafor	Assess financial impact and financial data exposure; authorize emergency expenditures for incident response; coordinate cyber insurance claims

Orbital Systems Security Analyst: Carlos E. Mendoza	Technical threat analysis; threat hunting; containment support; forensic evidence preservation
Physical Security Manager: Daniel J. Kowalski	Manage building access control and physical security during an incident; coordinate with law enforcement on physical aspects

3.2 Secondary IRT Members

Role / Vendor	Primary Responsibilities
Huntress (MDR Provider)	AI-powered threat detection; automatically quarantines affected endpoints upon threat detection to prevent lateral movement and network spread; technical mitigation and digital forensics support; 24/7 SOC coverage
Legal Counsel (External)	External legal advisor; regulatory compliance oversight; law enforcement liaison for criminal investigations; contract and liability matters
Public Relations Vendor	External public relations advisor during and after significant incidents affecting ZOS client or public communications
Cyber Insurance Provider	Cyber insurance advisor; claims coordination; coverage guidance; pre-breach planning consultation

4. Incident Response Lifecycle

Cyber incident response management is an ongoing process with a cyclical pattern. Each phase builds on the previous, and lessons learned from any incident are fed back into the preparation phase to continuously improve ZOS's response capabilities.

Phase	Description
1. Preparation	The ongoing process of maintaining and improving incident response capabilities and preventing incidents through secure systems, employee awareness training, and periodic tabletop exercises. Huntress provides continuous AI-powered threat detection and MDR as part of the preparation and monitoring posture. When a threat is detected, Huntress automatically quarantines the

	affected endpoint. Preparation is the only phase that occurs before an incident and never stops.
2. Identification	The process of confirming, characterizing, classifying, categorizing, scoping, and prioritizing suspected incidents. This phase determines whether an event is a true incident and establishes its type, impact, and severity.
3. Notification	Alerting IRT members to the occurrence of a confirmed incident and communicating status throughout the response. Communication channels, escalation paths, and notification timing are governed by the incident severity level.
4. Containment	Minimizing financial and reputational loss, theft of information, or service disruption. Includes initial public communications and legal notifications as required. The goal is to stop the bleeding without destroying forensic evidence. Huntress AI assists containment by automatically quarantining the affected endpoint the moment a threat is confirmed.
5. Eradication	Eliminating the threat from all affected systems. This includes removing malware, closing unauthorized access paths, patching exploited vulnerabilities, and resetting compromised credentials across the environment.
6. Recovery	Restoring systems and business operations to normal, verified clean states. Includes reputational repair, customer communications, credit monitoring for affected individuals, and legal remediation as appropriate.
7. Post-Incident	After recovery, formalize documentation of the incident, conduct lessons learned review with the full IRT, and apply learnings to future preparedness and update this plan accordingly.

5. Incident Occurrence and Awareness

The way an incident becomes known will have an impact on the response process and its urgency. Incidents may be discovered through any of the following channels:

1. ZOS discovers through its internal monitoring such as Huntress AI detection, Splunk SIEM alerts, or IDS/IPS notifications that a cyber incident or data breach

has occurred. Huntress will automatically quarantine the affected machine and notify IT immediately.

- 2. ZOS is notified by one of its technology providers, cloud service providers, or managed security service providers of an incident or potential breach.
- 3. ZOS is made aware of a breach through a constituent, customer, employee, or third-party informant who observed or was affected by suspicious activity.
- 4. ZOS and the public are made aware of the incident through news media, public disclosure, or regulatory notification from a third party affected by the same incident.

Regardless of the discovery channel, all suspected incidents must be reported immediately to the Head of Information Technology or the Incident Response Manager. No ZOS employee should attempt to investigate or respond to a suspected incident independently without notifying the IRT.

6. Incident Response Process Detail

Phase / Timing / Steps	Involved Parties
IDENTIFICATION (Hours): 1. Identify and confirm whether the suspected or reported incident has occurred and whether malicious activity is still underway. 2. Determine the type, impact, and severity per the matrix in Section 8. 3. If Huntress has already automatically quarantined the affected endpoint, verify the quarantine is active and confirm no other systems are impacted before proceeding with additional containment.	IT, Huntress (AI detection), and any monitoring service provider
NOTIFICATION (Hours to 1 Day): 4. Inform or activate the IRT based on incident severity as defined in Section 8.	IT and IRT

Provide incident type, impact, and all known details. 5. Determine whether Subject Matter Experts (SMEs) are required for Containment, Eradication, or Recovery.	
CONTAINMENT (Hours to 2 Days): 6. Take immediate steps to curtail ongoing malicious activity or prevent repetition. Note: Huntress auto-quarantine may have already isolated the affected system automatically. 7. Redirect public-facing websites if needed. 8. Provide initial public relations and legal responses as required.	IRT, IT, Huntress, SMEs
ERADICATION (Days to Weeks): 9. Provide full technical resolution of the threat and all related malicious activity. 10. Address public relations, regulatory notification, and legal issues. 11. Reset all compromised credentials and patch all exploited vulnerabilities.	IT, IRT, SMEs
RECOVERY (Weeks to Months): 12. Recover any business process disruptions and restore normal operations. 13.	SMEs, IRT

Address longer-term public relations or legal issues. 14. Apply constituent remedies such as credit monitoring or notification letters as required.	IRT
POST-INCIDENT (Months): 15. Formalize documentation of the incident including a complete incident timeline. 16. Conduct lessons learned review with the full IRT. 17. Apply learnings to future preparedness and update this plan accordingly.	

7. Communication Methods

ZOS organizational communication resources including email and phone systems may be compromised or unavailable during a severe incident. Primary and alternate out-of-band communication methods using external infrastructure must be established before any incident occurs and documented on the IRT member contact list. The IRM will designate which communication method will be used at the outset of any activated incident response.

Communication Method	Purpose and Usage
Organizational email (primary)	Standard day-to-day use; may be unavailable during severe incidents
Personal mobile phones (backup)	Out-of-band communication when ZOS organizational systems are unavailable
Encrypted messaging app (Signal)	Secure out-of-band communication for sensitive incident details during active response
Conference bridge (external)	IRT coordination calls when internal phone systems are unavailable

In-person meeting

Primary method for Severity 4 and 5 incidents where electronic systems cannot be trusted

8. Information Recording

Information recording is critical during an incident not only for effective containment and eradication, but also for post-incident lessons learned and any legal action that may follow. Accurate, timestamped records can be essential evidence in law enforcement investigations and regulatory inquiries.

Each member of the IRT is responsible for recording information and chronological references about their actions and findings during an incident using the IRT Incident Record Form in Appendix E of this plan. Records must include:

- Date and time of each action or observation
- Name of the individual recording the entry
- System, account, or data set affected
- Actions taken and their outcomes, including any Huntress automated actions such as endpoint quarantine
- Any communications made or received related to the incident

Incident records are considered confidential and legally sensitive. They must be stored securely and access restricted to IRT members and authorized legal counsel only.

9. Incident Response Exercises

The ZOS IRT must conduct tabletop exercises to practice the response process on a periodic basis, at minimum annually, so all members are familiar with their responsibilities and the coordination required during an actual incident. Exercises should be conducted every six months per Databarracks best practice guidance.

Tabletop exercises present realistic incident scenarios to the team in a practice setting without actual systems being affected. They provide the opportunity to identify gaps in the plan, test communication procedures, and improve team coordination. Common scenarios to exercise include:

- Ransomware attack encrypting ZOS ground station servers and triggering a Huntress automated quarantine
- Data breach involving PII exfiltration from ZOS HR systems
- DDoS attack against ZOS internet-facing satellite data relay API
- Insider threat accessing sensitive mission telemetry data without authorization
- Phishing campaign resulting in compromised executive credentials
- Physical breach of the MDF room or IDF closet
- Loss of ground-to-space link continuity requiring BCP activation

Lessons identified from exercises must be documented and incorporated into this plan and the organization's security controls. The IRM is responsible for scheduling, facilitating, and documenting all exercises.

10. Appendix A: IRT Incident Severity and Response Classification Matrix

Level	Typical Characteristics	Example Impact	Response Actions	Activate IRT?
5	DDoS against servers. Active attacks on network infrastructure. Access to internal data by unauthorized parties.	Enterprise-wide attack across multiple departments. Prevents access to systems. Theft of proprietary data.	IRT and IRM direct full response. Huntress MDR notified immediately; auto-quarantine verified. IT, Forensics, and SMEs coordinate remediation. Law enforcement and Legal Counsel engaged.	Full Team Active
4	Affects data or services for a group. Threatens sensitive data. Involves elevated privilege accounts.	Compromised business application. Improper or unauthorized access to data.	IRM, IT, Huntress (MDR), and SMEs coordinate response. Full IRT advised. Legal Counsel notified if PII breach.	Full Team Informed and Advised
3	Affects a single individual with significant sensitive data. May include PII.	Employee computer or account with sensitive data access compromised. Physical theft of device.	IT or IRM coordinates. Huntress auto-quarantine checked and confirmed if triggered. IRT members informed. Legal Counsel notified if PII breach.	Primary Team Informed

2	Affects a group with no sensitive data involved.	Compromise of an account or shared folder with no sensitive data.	IT coordinates response. IRM advised, IRT informed. Huntress portal reviewed for related alerts. IT documentation records findings.	Primary Team Informed
1	Affects a single individual with no sensitive data. Focus is correction and prevention.	Compromised computer with no sensitive data.	Documentation of issue and findings. IT/IRM coordinate remediation.	No
0	Very minor or undetermined incident with no practical follow-up needed.	Impaired computer requiring AV scan or password reset.	Documentation through normal IT support processes. Reset passwords as needed.	No

11. Appendix B: IRT Member Contact List

Contact information for all IRT members must be maintained, circulated to the team, and stored both digitally and in printed form. The printed copy must be stored securely off-system in the biometric safe in the ZOS MDF room in case digital systems are unavailable during an incident.

Name / Role	Contact Information
Noe Valencia, Head of IT / IRM	Work: (214) 555-0147 Mobile: [Mobile] Alt Email: noe.valencia.alt@zos-secure.com
Michael R. Torres, Director of Mission Assurance	Work: [Work Phone] Mobile: [Mobile] Alt Email: [Alt Email]
Gregory A. Whitfield, General Counsel	Work: [Work Phone] Mobile: [Mobile] Alt Email: [Alt Email]

Sandra L. Pham, HR and Communications Director	Work: [Work Phone] Mobile: [Mobile] Alt Email: [Alt Email]
Rachel M. Okafor, CFO	Work: [Work Phone] Mobile: [Mobile] Alt Email: [Alt Email]
Carlos E. Mendoza, Orbital Systems Security Analyst	Work: [Work Phone] Mobile: [Mobile] Alt Email: [Alt Email]
Daniel J. Kowalski, Ground Systems IT Manager / Physical Security	Work: [Work Phone] Mobile: [Mobile] Alt Email: [Alt Email]
Huntress MDR (External SME)	Portal: [Huntress Portal] Hotline: [Hotline] support@huntress.com
External Legal Counsel	[Law Firm] [Phone] [Mobile] [Email]
Cyber Insurance Provider	[Insurance Provider] [Phone] [Email]

12. Appendix C: IRT Incident Record Form

Each IRT member must use this form to record all actions, observations, and communications during an active incident. Accuracy and timestamps are critical for post-incident analysis and any potential legal proceedings. Include any automated actions taken by Huntress such as endpoint quarantine events.

Field	Entry
Incident Designation	
Discovery Date	
Severity Level	
Recorded By	
IRT Role	

Date / Time	Recorded Information and Events

13. Sources and References

- SANS Institute Cybersecurity Incident Response Plan Template. <https://www.sans.org/information-security-policy/>
- NIST SP 800-61 Rev 2, Computer Security Incident Handling Guide. <https://csrc.nist.gov>
- CISA Incident Response Guidance. <https://www.cisa.gov/resources-tools/resources/incident-response-guide>
- Databarracks Business Continuity and Incident Response best practices. <https://www.databarracks.com>
- Huntress MDR Platform Documentation. <https://www.huntress.com>

ZENITH ORBITAL SYSTEMS

Cybersecurity Management Plan

Adaptive Security and Zero Trust Operations Framework (AZTOF) v2.0

Effective: April 2026 | Next Review: April 2027

Prepared by: Noe Valencia, PSSE

1. Introduction

Cybersecurity is not optional anymore. IBM reported the global average cost of a data breach hit \$4.88 million in 2024, and U.S. organizations averaged \$10.22 million per incident. Cybercrime costs as a whole are projected to hit \$10.5 trillion annually by 2025. The attack methods are not mysterious either. The human element (social engineering, errors, and credential misuse) shows up in about 60% of breaches per the 2025 Verizon DBIR, with stolen credentials at 22%, vulnerability exploitation at 20%, and phishing at 16% of initial access vectors. Ransomware showed up in 44% of breaches in the most recent Verizon DBIR, up from 32% the year before. Attackers are also getting faster. The median time from initial access to ransomware execution dropped to just five days in 2025. Identity attacks account for nearly 90% of incident response cases, and 97% of those use nothing more than stolen or guessed passwords.

The frameworks we use to manage these risks have been updated too. NIST released CSF 2.0 in February 2024. The biggest change was adding a sixth function called Govern, which puts cybersecurity governance at the same level as any other enterprise risk. CISA updated their Zero Trust Maturity Model to version 2.0. The CISA Known Exploited Vulnerabilities catalog grew to 1,484 entries by end of 2025, a 20% jump from the year before.

This Cybersecurity Management Plan is built around the Adaptive Security and Zero Trust Operations Framework, or AZTOF. It pulls from NIST CSF 2.0, NIST SP 800-207, CISA ZTMM 2.0, and MITRE ATT&CK. Fayol's five management functions (Forecasting, Planning, Organizing, Coordinating, and Controlling) are used to manage each of the six AZTOF domains. For ZOS, the stakes are elevated beyond the standard enterprise context: a cybersecurity failure is not just a data breach, it is a potential loss of command authority over hardware in orbit.

The six domains covered in this plan are:

- Identity and Access Governance (IAG)
- Threat Detection and Incident Response (TDIR)
- Data Protection and Privacy (DPP)
- Vulnerability and Configuration Management (VCM)
- Regulatory Compliance and Audit Readiness (RCAR)
- Security Culture and Workforce Resilience (SCWR)

2. AZTOF Governance Framework

2.1 Framework Foundations

AZTOF is built on four current frameworks. Each one was picked because it addresses something specific and relevant to ZOS operations.

NIST Cybersecurity Framework 2.0 (Released February 26, 2024): This is the most significant update to the CSF since it was first published in 2014. The big change is the new Govern function. It sits at the center of the framework and connects to all five other functions. That placement is intentional. It signals that governance is not a supporting activity, it is the core. CSF 2.0 also expanded scope so it applies to all organizations, not just critical infrastructure. AZTOF maps all six of its domains to the CSF 2.0 functions.

NIST SP 800-207 (Zero Trust Architecture): NIST SP 800-207 defines Zero Trust through seven tenets. The core idea is that no user, device, or network is trusted by default. Access is granted per session based on dynamic policy and continuous verification. AZTOF's Identity and Access Governance domain is built directly on these principles.

CISA Zero Trust Maturity Model 2.0: CISA's ZTMM 2.0 breaks Zero Trust down into five pillars: Identity, Devices, Networks, Applications and Workloads, and Data. The model defines four maturity stages: Traditional, Initial, Advanced, and Optimal. AZTOF uses the ZTMM 2.0 as the Zero Trust maturity assessment tool. The ZOS target is reaching the Advanced stage across all five pillars within 36 months.

MITRE ATT&CK Enterprise Framework: MITRE ATT&CK is a catalog of real adversary tactics, techniques, and procedures based on observed attacks. AZTOF uses it for threat modeling, detection gap analysis, and red and purple team exercise design. Mapping Splunk SIEM detection rules to ATT&CK techniques gives a structured way to find and close blind spots in detection coverage.

2.2 AZTOF Domain Descriptions

Domain 1: Identity and Access Governance (IAG): IAG covers who and what can access ZOS systems, data, and resources. Given that 97% of identity attacks use stolen or guessed passwords and identity weaknesses show up in nearly 90% of IR investigations, this is the highest-impact domain in the framework. IAG enforces MFA for everyone, implements privileged access management, pushes toward phishing-resistant FIDO2 authentication for high-privilege roles, and manages the full identity lifecycle from hire to termination.

Domain 2: Threat Detection and Incident Response (TDIR): TDIR covers the ability to detect attacks through Splunk SIEM and Huntress EDR tools mapped to MITRE ATT&CK, triage and validate alerts through a SOC function, contain and eradicate threats, and recover in a controlled and documented way. With ransomware executing in a median of five days from initial access, detection speed directly determines how bad the outcome is for ZOS mission continuity.

Domain 3: Data Protection and Privacy (DPP): DPP covers how ZOS data is classified, protected, and processed throughout its lifecycle. For ZOS, data includes

mission-critical satellite telemetry, defense client relay data, personnel records, and financial information. Each data type carries different regulatory obligations and operational sensitivity.

Domain 4: Vulnerability and Configuration Management (VCM): VCM covers how ZOS identifies, prioritizes, and remediates vulnerabilities and configuration weaknesses across its entire asset inventory. Given that ZOS operates infrastructure where a single exploited vulnerability could compromise satellite command capability, VCM is a mission-critical function, not a routine IT task.

Domain 5: Regulatory Compliance and Audit Readiness (RCAR): RCAR covers how ZOS maintains compliance with applicable regulatory frameworks and prepares for internal and external audits. For ZOS, compliance obligations include CMMC Level 2 (defense client contracts), NIST CSF 2.0, CIS Controls v8, and the Texas Data Privacy and Security Act.

Domain 6: Security Culture and Workforce Resilience (SCWR): SCWR recognizes that technology controls are only as effective as the people operating within them. Human error, social engineering, and insider threat collectively account for a majority of breaches. SCWR builds security awareness, instills secure behaviors, and ensures ZOS personnel are prepared to recognize and respond to threats.

3. Fayol's Management Functions Applied to Each AZTOF Domain

3.1 Identity and Access Governance (IAG)

Threat context: Identity attacks account for 65% of initial access in IR investigations. Modern MFA prevents more than 99% of identity-based attacks. Despite that, cloud identities are found to be over-permissioned in 99% of large-sample audits. The least-privilege gap is real and widespread.

Forecasting: Quarterly threat intelligence reviews will track emerging identity attack methods including adversary-in-the-middle phishing, SIM swapping, and session token hijacking. ZOS will subscribe to CISA advisories and relevant ISAC feeds for early warning. Annual MFA coverage audits will measure the gap between current enrollment and the 100% target across all user types. CISA ZTMM 2.0 Identity pillar maturity assessments will define the roadmap to the next stage.

Planning: An annual Identity Security Roadmap will prioritize: getting MFA to 100% across all user types; migrating high-privilege accounts to FIDO2 phishing-resistant authenticators; deploying CyberArk PAM covering all privileged accounts; and formalizing RBAC matrices with documented access request, approval, and review workflows. Conditional access policies will enforce device compliance as a condition of network access per NIST SP 800-207.

Organizing: An Identity Governance team will be established in the ZOS IT Security function. It will include an IAM Engineer who handles directory services, provisioning, and MFA platform management, and a Privileged Access Administrator who runs the CyberArk PAM tool and monitors privileged sessions. RACI matrices will define ownership for every identity governance process.

Coordinating: IAG activities will be formally tied into HR's joiner, mover, and leaver processes with automated triggers for provisioning, access changes, and deprovisioning. The target is under four hours from termination notification to account deactivation. Legal and Procurement will set contractual identity standards for vendors so third-party access stays least-privilege. A quarterly Identity Review Board with IT Security, HR, Legal, and Business Unit leads will govern access exceptions.

Controlling: Monthly access certifications reviewing all active accounts and their permissions. Dormant accounts flagged for review after 30 days of inactivity. 100% MFA enrollment target tracked monthly. Monthly CISO reporting on IAG KPIs including privileged account count, deprovisioning SLA compliance, and MFA enrollment rate.

3.2 Threat Detection and Incident Response (TDIR)

Threat context: Ransomware showed up in 44% of breaches in the 2025 Verizon DBIR. Attackers are deploying ransomware in a median of five days from initial access. For ZOS, a ransomware event affecting ground station systems during an active mission could result in loss of satellite command capability.

Forecasting: CTI program with CISA KEV and MITRE ATT&CK threat modeling. Annual tabletop exercises and 18-month red/purple team exercises. ZOS-specific threat scenarios include satellite ground station targeting, SDR interface exploitation, and terrestrial API attacks against ZOS client-facing systems.

Planning: Comprehensive Incident Response Plan developed, reviewed annually, and exercised twice a year. The IRP defines five severity levels (P1 through P5), escalation paths, communication templates, regulatory notification timelines, and recovery time objectives per system tier. A dedicated ransomware playbook addresses double-extortion scenarios including data exfiltration before encryption, negotiation decision criteria, and backup-based recovery. AI-driven detection built into Splunk SIEM to reduce mean time to detect.

Organizing: Virtual SOC staffed by in-house Tier 1 analysts with Huntress MDR covering Tier 2 and Tier 3 escalations and 24/7 monitoring. Pre-constituted IRT with defined roles: IRM (Noe Valencia), Mission Assurance Director (Michael R. Torres), Technical Lead (Carlos E. Mendoza), Communications Lead (Sandra L. Pham), and Legal/Compliance Liaison (Gregory A. Whitfield). All IRT members participate in at least two exercises per year. On-call schedules, out-of-band communication channels, and escalation contact trees are documented, tested, and updated quarterly.

Coordinating: TDIR coordinated with Business Continuity Management to ensure the IRP and BCP align and that RTO and RPO targets are consistent. Pre-established protocols with the FBI Cyber Division (IC3), CISA, and external cybersecurity legal counsel are in place before any incident happens. Splunk SIEM ticketing integrates with IT Operations workflows so remediation actions move through the change management process. Post-incident communications are reviewed by Legal before any external disclosure.

Controlling: Monthly SOC Metrics Dashboard tracks: MTTD by severity (P1 target under 30 minutes); MTTR by severity (P1 target under 4 hours); false positive rate (target under 20%); and incident recurrence rate (target zero for closed incidents).

Mandatory Post-Incident Reviews completed within 5 business days for all P1 and P2 incidents. Semi-annual IRP exercises include at least one unannounced drill per year.

3.3 Data Protection and Privacy (DPP)

Forecasting: Annual data discovery and classification review to identify new data types and update classification. Regulatory horizon calendar maintained 180+ days ahead for GDPR, HIPAA, TDPSA, and CMMC updates. Data breach trend analysis from Verizon DBIR and IBM Cost of a Breach Report informs ZOS DPP priority setting.

Planning: Four-tier data classification policy (Mission Critical, Confidential, Internal, Public) with corresponding handling requirements. AES-256 encryption at rest and TLS 1.3 in transit as the ZOS baseline. Data Protection Impact Assessment (DPIA) process for new data processing activities. Data Processing Agreements (DPAs) and Business Associate Agreements (BAAs) scheduled and tracked.

Organizing: Data Protection Officer (DPO) function established within ZOS IT Security. Embedded business unit data stewards accountable for classification and handling within their functions. Zscaler CASB deployed for DLP monitoring and control. All new vendors must pass a security assessment before receiving access to ZOS data.

Coordinating: Legal engagement for BAA and GDPR obligations. Procurement enforces DPA requirements as a contract condition. DPP activities integrated with TDIR IRP so data breach response procedures align with classification and regulatory notification requirements.

Controlling: Monthly DLP exception review. 100% encryption target for all data in transit and at rest. Annual privacy audits. Third-party attestation tracking for all Tier 1 CSPs.

3.4 Vulnerability and Configuration Management (VCM)

Forecasting: CISA KEV catalog monitored multiple times per week. CMDB cross-referencing ensures all assets are tracked. NVD and vendor advisory feeds subscribed for ZOS-relevant technologies including Palo Alto, Cisco, Dell, and Meraki.

Planning: KEV 48-hour remediation SLA for all CISA KEV-listed vulnerabilities. Critical (non-KEV) 15-day SLA. High 30-day SLA. Medium 90-day SLA. CIS Benchmark-aligned configuration baselines for all ZOS network device types. Annual third-party penetration test required.

Organizing: Vulnerability Management Engineer role established in IT Security. Qualys VMDB deployed across all 500+ ZOS assets. CMDB maintained and current. Monthly Configuration Compliance Working Group reviews drift reports and assigns remediation owners. DevSecOps integration extends secure configuration standards into ZOS operational systems.

Coordinating: VCM integrates with the IT Change Management process so patches deploy through controlled change windows. Emergency change procedures pre-defined for KEV and critical actively exploited vulnerabilities, allowing accelerated deployment with appropriate approvals. VCM coordinates with TDIR so that any KEV-listed

vulnerability affecting the ZOS environment triggers threat hunting in the vSOC concurrently with patching.

Controlling: Monthly vulnerability dashboards report open findings by severity and SLA status, patch coverage by asset tier, and KEV remediation compliance. Configuration compliance scans run weekly with automated reports to system owners for any drift. KPIs: KEV 48-hour remediation compliance target 100%; Critical SLA compliance target over 95%; assets with verified baseline configuration target over 98%; open critical findings older than 15 days target zero.

3.5 Regulatory Compliance and Audit Readiness (RCAR)

Forecasting: Regulatory horizon calendar tracks proposed rules, effective dates, and projected compliance gaps, with legal counsel engaged for regulatory changes that have 12 to 18 months of lead time. Cyber insurance renewal cycles serve as structured forcing functions to assess and demonstrate compliance posture improvements. ZOS compliance obligations: HIPAA for healthcare data handling, GDPR and CCPA for personal data, CMMC Level 2 for defense contracts, and TDPSA for Texas operations.

Planning: Annual Compliance Work Plan maps all applicable regulatory requirements to specific AZTOF controls, assigns control owners, and schedules internal audits and external assessments. Continuous Controls Monitoring through Archer GRC automates evidence collection for SOC 2 and applicable compliance controls. The control library aligns to NIST CSF 2.0, which cross-references ISO 27001, CIS Controls, and the HIPAA Security Rule so ZOS gets multi-framework coverage efficiently.

Organizing: Compliance and Risk Manager established in the ZOS IT Security function with dotted-line reporting to Legal. This role owns the Risk Register, coordinates internal audits, manages relationships with external auditors, and handles regulatory inquiries. Archer GRC is the system of record for policies, controls, evidence, risk register entries, and audit findings.

Coordinating: Finance reflects cybersecurity compliance obligations in budgeting and cyber insurance requirements. Procurement enforces third-party compliance requirements as a contract condition. The Compliance and Risk Manager presents the compliance posture to ZOS executive leadership and the board quarterly, consistent with CSF 2.0's Govern function requirement for leadership engagement.

Controlling: Annual SOC 2 audit. CMMC Level 2 assessment. Internal audit findings tracked to closure in Archer GRC. External auditor relationships managed with defined engagement timelines.

3.6 Security Culture and Workforce Resilience (SCWR)

Forecasting: Annual phishing susceptibility baseline measurement using KnowBe4 simulations. Workforce risk profiling to identify departments and roles with elevated social engineering exposure. Security culture survey administered annually to measure attitudes, behaviors, and knowledge gaps. AI-driven phishing campaign data reviewed quarterly to update simulation scenarios.

Planning: KnowBe4 quarterly training calendar with role-specific content for general staff, IT administrators, executives, and new hires. Biannual IRT tabletop exercise schedule including at least one unannounced drill per year. New hire security onboarding completed before first system access is granted. Executive security briefing program to ensure leadership understands the ZOS threat landscape.

Organizing: Security Awareness Lead designated within ZOS IT Security. KnowBe4 platform managed by the Security Awareness Lead. Phishing simulation campaign library maintained and rotated quarterly to prevent habituation. Role-based training tracks developed for general staff, system administrators, finance, and HR.

Coordinating: HR integration for new hire onboarding ensures all new ZOS employees complete security training before receiving access credentials. Security culture data coordinated with TDIR for exercise scenario development and post-incident lessons learned. Annual security awareness report shared with ZOS executive leadership.

Controlling: Monthly phishing click rate tracked by department (target below 5%). Quarterly training completion rate (target 100% within 30 days of assignment). Exercise after-action reports reviewed by IRM and IT Security Manager within 10 business days of exercise completion. Annual security culture survey results reported to executive leadership.

4. AZTOF Governance Summary Matrix

This table summarizes Fayol's five management functions across all six AZTOF domains. It is the quick-reference governance tool for the CISO, executive leadership, and auditors.

DOMAIN	FORECASTING	PLANNING	ORGANIZING	COORDINATING	CONTROLLING
IAG	Quarterly identity threat reviews; CISA ZTMM Identity pillar assessment; MFA coverage gap analysis	Annual Identity Security Roadmap; FIDO2 for privileged roles; RBAC matrices with access workflows	IAM Engineer and Privileged Access Admin; CyberArk PAM deployment; Okta SSO and lifecycle platform	HR joiner/mover/leaver integration; under 4 hour deprovisioning SLA; quarterly Identity Review Board	Monthly access certifications; dormant account flagging; 100% MFA target; monthly CISO reporting
TDIR	CTI program with CISA KEV and MITRE ATT&CK; annual tabletop; 18-month red/purple team exercises	IRP with P1 through P5 severity levels; ransomware double-extortion playbook; regulatory notification timelines	vSOC with 24/7 Huntress MDR partner; pre-constituted IRT with defined roles; out-of-band comms tested quarterly	Integrated with BCM; pre-established FBI IC3, CISA, and legal counsel protocols; Splunk SIEM to ITSM ticketing	P1 MTTD under 30 min; P1 MTTR under 4 hours; mandatory PIRs within 5 days; semi-annual IRP exercises
DPP	Annual data discovery and classification; regulatory horizon	4-tier classification policy; AES-256 and TLS 1.3	DPO and embedded data stewards; DLP tooling; vendor	Legal for BAA and GDPR; Procurement for vendor risk; integrated with TDIR IRP	Monthly DLP exception review; 100% encryption target; annual privacy

	calendar 180+ days ahead	standards; DPIA process; DPA and BAA schedule	security assessment before onboarding		audits; third-party attestation tracking
VCM	CISA KEV catalog monitoring multiple times per week; CMDB cross-referencing; NVD and vendor advisory feeds	KEV 48-hour SLA; Critical 15-day SLA; High 30-day SLA; CIS Benchmark baselines	Vulnerability Management Engineer; Qualys VMDR deployment; CMDB maintained; monthly Compliance Working Group	Patch windows coordinated with IT Operations; emergency change procedures for KEV; VCM coordinates with TDIR	Weekly Qualys scan reports; monthly vulnerability trend analysis; annual pen test findings review; KPI dashboards
RCAR	Regulatory horizon calendar 180+ days ahead; cyber insurance renewal as forcing function	Annual Compliance Work Plan; continuous controls monitoring via Archer GRC; multi-framework alignment	Compliance and Risk Manager; Archer GRC as system of record; external auditor relationships managed	Finance for budgeting obligations; Procurement for third-party compliance; quarterly board reporting	Annual SOC 2 audit; CMMC Level 2 assessment; internal audit findings tracked to closure in GRC
SCWR	Annual phishing susceptibility baseline; workforce risk profiling; security culture survey	KnowBe4 quarterly training calendar; biannual IRT tabletop exercise schedule; new hire security onboarding	Security Awareness Lead; KnowBe4 platform managed; phishing simulation campaign library maintained	HR integration for new hire onboarding; coordinated with TDIR for exercise scenarios and lessons learned	Monthly phishing click rate tracked; quarterly training completion rate; exercise after-action reports reviewed

5. Conclusion

The threat environment is not slowing down. Global average breach costs hit \$4.88 million in 2024. Ransomware showed up in 44% of breaches. Attackers are deploying ransomware in a median of five days from initial access. CISA added 245 new confirmed-exploited vulnerabilities to their catalog in 2025 alone. AI now drives over 80% of phishing campaigns. These are not projections. They are current data points.

AZTOF is built to address this environment directly. It pulls from NIST CSF 2.0 including the new Govern function, CISA's Zero Trust Maturity Model 2.0, NIST SP 800-207, and MITRE ATT&CK. The six governance domains cover identity, detection and response, data protection, vulnerability management, compliance, and workforce resilience. Fayol's management functions make sure each domain is run with clear ownership, defined activities, and measurable outcomes.

For ZOS, AZTOF is not just a compliance framework. It is the governance structure that protects the ground infrastructure supporting every orbital mission we manage. This plan gets reviewed annually. The CISO leads the review with executive leadership and the board in line with CSF 2.0's Govern function requirements. As the threat environment changes, as regulations update, and as ZOS grows, the specific activities

within each AZTOF domain get updated to match. The framework stays stable. The activities inside it stay current.

6. References and Sources

- NIST CSF 2.0. February 26, 2024. <https://csrc.nist.gov/pubs/cswp/29>
- NIST SP 800-207: Zero Trust Architecture. 2020.
- NIST NCCoE SP 1800-35: Implementing a Zero Trust Architecture. June 2025.
- CISA Zero Trust Maturity Model v2.0. April 2023. <https://www.cisa.gov/zero-trust-maturity-model>
- CISA Known Exploited Vulnerabilities (KEV) Catalog. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- IBM Security. Cost of a Data Breach Report 2024. 2024.
- Verizon. 2025 Data Breach Investigations Report (DBIR). 2025.
- Sophos. State of Ransomware 2025. 2025.
- IBM X-Force. Threat Intelligence Index 2025. 2025.
- MITRE ATT&CK Enterprise Framework. <https://attack.mitre.org>

ZENITH ORBITAL SYSTEMS

IT Department Business Continuity Plan

Ground-to-Space Link Redundancy Edition

Version 1.00 | Last Updated: February 25, 2026 | Next Review: February 2027

Prepared by: Noe Valencia, PSSE

CONFIDENTIAL | Document for Internal Use by ZOS Personnel Only

Section I: Introduction

A. How to Use This Plan

In the event of a disaster which interferes with Zenith Orbital Systems' ability to conduct business from its primary Dallas ground station facility, this plan is to be used by the responsible individuals to coordinate the business recovery of their respective areas and departments. The plan is designed to contain, or provide reference to, all of the information that might be needed at the time of a business recovery.

This plan is not intended to cover the operations of the ZOS separately structured Emergency Response Team. Index of Acronyms: (EOC) Emergency Operations Center; (EMT) Emergency Management Team; (ERT) Emergency Response Team; (BCP) Business Continuity Plan; (IT) Information Technology; (ZOS) Zenith Orbital Systems; (GSL) Ground-to-Space Link.

Section I, Introduction, contains general statements about the organization of the plan. Section II, Business Continuity Strategy, describes the strategy the IT Department will implement to maintain business continuity in the event of a facility disruption. Section III, Recovery Teams, lists the Recovery Team functions, those individuals assigned specific responsibilities, and procedures on how each team member is to be notified. Section IV, Recovery Procedures, determines what activities and tasks are to be taken, in what order, and by whom in order to affect the recovery. Section V, Appendices, contains all other information needed to carry out the plan.

B. Objectives

The objective of the Business Continuity Plan is to coordinate recovery of critical ZOS business functions in managing and supporting the business recovery in the event of a facilities disruption or disaster. This can include short or long-term disasters or other disruptions, such as fires, floods, earthquakes, explosions, terrorism, tornadoes, extended power interruptions, hazardous chemical spills, and other natural or man-made disasters.

A disaster is defined as any event that renders a ZOS business facility inoperable or unusable so that it interferes with the organization's ability to deliver essential business services. For ZOS, the critical service that must be maintained above all others is continuous Ground-to-Space Link (GSL) capability, which is the ability to command and control ZOS orbital assets. All BCP objectives flow from that requirement.

C. Scope and Applicability

This BCP applies to the ZOS Dallas ground station facility as the primary site. It covers the recovery of all IT infrastructure, orbital operations, personnel functions, financial operations, legal functions, and client communications necessary to sustain ZOS mission operations during and after a facility disruption. The Austin relay hub serves as the primary alternate site for GSL operations.

Section II: Business Continuity Strategy

A. Ground-to-Space Link Redundancy

ZOS operates orbital assets that require continuous ground command and control. The loss of the Dallas primary ground station without an active failover plan means loss of satellite command authority. This BCP is built specifically around maintaining GSL continuity through the Austin relay hub operated by Kevin D. Nguyen, Austin Relay Hub Operations Lead.

GSL failover procedures are classified as Priority One recovery activities. All other recovery activities are subordinate to maintaining orbital asset command capability. The Recovery Time Objective (RTO) for GSL failover activation is 4 hours from the declaration of a facility disruption.

B. Recovery Strategy Overview

ZOS will implement a hot/warm site recovery strategy. The Austin relay hub maintains near-real-time configuration synchronization with the Dallas primary ground station and can assume GSL operations within the 4-hour RTO. All other functions (administration, finance, HR, legal) will operate from remote work arrangements or the Austin site for up to 2 weeks. Recovery of the Dallas primary site is targeted within 3 to 7 days for IT infrastructure and up to 30 days for full facility restoration.

C. Business Impact Analysis Summary

The following ZOS functions have been assessed for criticality and recovery priority:

Function	Recovery Priority / RTO
Ground-to-Space Link (GSL) Command Operations	Priority 1 / 4 hours
Mission Telemetry Data Processing	Priority 1 / 4 hours

IT Infrastructure (core network, servers, SIEM)	Priority 2 / 24 hours
Client Communications and Data Relay Services	Priority 2 / 24 hours
Personnel Notification and HR Functions	Priority 3 / 48 hours
Financial Operations and Payroll	Priority 3 / 72 hours
Legal and Contract Management	Priority 4 / 5 business days
Administrative and Facilities Functions	Priority 5 / As feasible

D. Recovery Phases

Phase	Description
Phase I: Disaster Occurrence	Initial response to the disaster or disruptive event. Damage assessment, life safety, and initial notification of key personnel. GSL failover assessment begins immediately.
Phase II: Plan Activation	Notification and assembly of the BCP Recovery Team. Review and confirmation of the recovery strategy. Activation of the Austin relay hub if GSL continuity is threatened.
Phase III: Alternate Site Operations	Full operation from the Austin alternate site or remote work arrangements. GSL operations transferred to Austin. Client communications managed centrally.
Phase IV: Return to Normal Operations	Restoration of the Dallas primary site. Validation and testing of restored systems. Phased return of operations from Austin to Dallas. After-action review.

Section III: Recovery Teams

A. Purpose and Objective

This section identifies who will participate in the ZOS recovery process. The participants are organized into teams. Each team has a designated team leader and an alternate. Team members are assigned either to specific responsibilities or as members to carry out tasks as needed.

B. Recovery Team Assignments

Name / ZOS Title / BCP Role	Floor / Contact / Comments
Michael R. Torres Director of Mission Assurance and Continuity Incident Commander	Floor 3 m.torres@zos-secure.com Primary point of contact during all recovery operations; activates BCP; authorizes GSL failover
Daniel J. Kowalski Ground Systems IT Manager IT Recovery Lead and Alternate Team Leader	Floor 1 d.kowalski@zos-secure.com Leads IT infrastructure recovery; manages server and network restoration
Sandra L. Pham HR and Communications Director Public Information Officer and Alternate Team Leader	Floor 2 s.pham@zos-secure.com Handles internal and external communications; employee notifications; media liaison
Rachel M. Okafor Chief Financial Officer Finance and Admin Lead	Floor 4 r.okafor@zos-secure.com Manages financial continuity; emergency expenditure authorization; insurance claims
Gregory A. Whitfield General Counsel and Compliance Officer Legal and Contracts Lead	Floor 4 g.whitfield@zos-secure.com Oversees vendor and contract obligations during recovery; regulatory notifications
Lisa M. Cabrera Dallas Ground Station Operations Lead Business Function Leader (Dallas)	Floor 2 l.cabrera@zos-secure.com Coordinates Dallas site operations during recovery; liaison to facility management

Kevin D. Nguyen Austin Relay Hub Operations Lead Business Function Leader (Austin Failover)	Austin Site k.nguyen@zos-secure.com Activates and manages Austin relay hub GSL operations; assumes command authority during Dallas outage
James R. Holloway Satellite Network Administrator Network and Systems Recovery Lead	Floor 1 j.holloway@zos-secure.com Supports Kowalski with server and network recovery; ZOS network configuration restoration
Carlos E. Mendoza Orbital Systems Security Analyst Cybersecurity Recovery Monitor	Floor 1 c.mendoza@zos-secure.com Monitors systems for threats during recovery; verifies security posture before restoration
Patricia M. Solis Payroll and Accounting Finance Recovery Support	Floor 4 p.solis@zos-secure.com Assists Okafor with financial operations and payroll continuity
Thomas W. Brandt Facilities Manager Physical Site and Relocation Coordinator	Floor 1 t.brandt@zos-secure.com Coordinates physical site access and relocation logistics; vendor coordination for repairs
Angela C. Rivera HR Coordinator Employee Notifications	Floor 2 a.rivera@zos-secure.com Supports Pham with employee notifications and welfare tracking
Marcus L. Webb IT Support Technician End-User Recovery Support	Floor 1 m.webb@zos-secure.com End-user support during recovery; workstation setup at alternate site
Jennifer T. Walsh Operations Manager Day-to-Day Recovery Coordination	Floor 3 j.walsh@zos-secure.com Oversees day-to-day recovery task coordination across all teams
Donna K. Fields Executive Assistant 	Floor 3 d.fields@zos-secure.com Administrative support to Incident Commander Torres; scheduling and documentation

Administrative Support to Incident Commander	
Noe Valencia Principal Systems Security Engineer Security Recovery Coordinator	Floor 1 noe.valencia@zos-secure.com Security oversight of all recovery activities; coordinates with Huntress MDR during recovery; validates security posture before return to operations

C. Personnel Notification

Personnel notification follows the call tree structure defined in Appendix A. The Incident Commander (Michael R. Torres) initiates the call tree upon declaration of a disaster. If Torres is unavailable, Daniel J. Kowalski or Sandra L. Pham serve as alternate team leaders and initiate notification. Notification can also be made using reverse 911 or other mass notification systems. The Austin relay hub (Kevin D. Nguyen) is on a separate notification path to ensure GSL failover can proceed independently of Dallas site status.

Section IV: Recovery Procedures

Phase I: Disaster Occurrence

ACTIVITY: Initial Response and Damage Assessment

PERFORMED AT: Primary or Alternate Location

RESPONSIBILITY: Incident Commander / Senior Management on Site

1. The senior ZOS manager present at or first aware of the disaster activates emergency response and notifies the Incident Commander (Michael R. Torres) immediately.
2. If the disaster threatens immediate life safety, evacuate the facility per established ZOS emergency evacuation procedures before initiating BCP activities.
3. The Incident Commander assesses the nature and scope of the disaster and determines whether BCP activation is required.
4. Carlos E. Mendoza conducts an immediate cybersecurity assessment to determine if the disaster is accompanied by or caused by a cyber incident. If a cyber incident is suspected, activate the Incident Response Plan concurrently with BCP procedures.
5. Kevin D. Nguyen at the Austin relay hub is notified immediately of any event that may threaten Dallas GSL capability. Nguyen places Austin operations on standby for immediate GSL failover.
6. If GSL capability is threatened or lost, Nguyen activates Austin relay hub GSL operations without waiting for formal BCP declaration.

Phase II: Plan Activation

ACTIVITY: Notification and Assembly of Recovery Teams and Employees**PERFORMED AT: Alternate Site / Emergency Operations Center****RESPONSIBILITY: IT Management Team**

1. The Incident Commander calls each member of the management team, instructs them of what time frame to assemble at the Emergency Operations Center, and to bring their copies of the Plan. The EOC location is the Austin relay hub or an alternative location designated at the time based on accessibility.
2. Review the recovery strategy and action plan with the assembled team.
3. If necessary, adjust management team assignments based on which members are available.
4. The Management Team contacts critical employees and tells them to assemble at the alternate site. Non-critical employees are instructed to stay at home and work remotely until notified otherwise.
5. In the event of a disaster that affects telecommunications service regionally, the Management Team should instruct critical employees to proceed to the Austin alternate site even if they have not been contacted directly.
6. Daniel J. Kowalski assesses the status of all ZOS IT infrastructure and determines the recovery approach for servers, network devices, and communications systems.
7. Noe Valencia verifies the security status of all systems, confirms Huntress MDR is active and monitoring, and ensures no active cyber threat is complicating the recovery.

Phase III: Alternate Site Operations**ACTIVITY: Alternate Site Processing Procedures****PERFORMED AT: Austin Relay Hub / Remote Work Locations****RESPONSIBILITY: Alternate Site Operations Team**

1. Kevin D. Nguyen confirms full GSL operational capability at the Austin relay hub and notifies the Incident Commander that command and control of ZOS orbital assets has been successfully transferred.
2. Sandra L. Pham communicates with ZOS clients regarding the disaster, confirms continuity of satellite data relay services through the Austin hub, and manages all external communications.
3. Daniel J. Kowalski initiates IT infrastructure recovery from Veeam backups. Recovery sequence: (1) Domain controllers and Active Directory; (2) Core networking and firewall configuration; (3) Application servers; (4) File servers and data; (5) Communication systems.
4. Noe Valencia verifies the integrity of all backup data before restoration using Veeam backup integrity checks. No system is returned to production without security verification.
5. Thomas W. Brandt coordinates with facility management, insurance, and vendors for Dallas site damage assessment, cleanup, and repair timeline estimation.

6. Rachel M. Okafor activates emergency financial procedures, authorizes recovery expenditures, and coordinates with the cyber insurance provider if the disaster involved a covered cyber event.
7. Jennifer T. Walsh tracks all recovery tasks, maintains the recovery log, and provides status updates to the Incident Commander at defined intervals.

Phase IV: Return to Normal Operations

ACTIVITY: Restoration and Return to Primary Site

PERFORMED AT: Dallas Primary Facility (when restored)

RESPONSIBILITY: Full Recovery Team

1. Thomas W. Brandt confirms the Dallas primary facility is structurally safe, has restored utilities, and is ready for occupancy.
2. Daniel J. Kowalski conducts a full technical readiness assessment of all restored IT infrastructure before returning any systems to production. This includes network device configuration verification against baseline, server integrity validation, and Splunk SIEM operational confirmation.
3. Noe Valencia conducts a security validation assessment including: verification of all access credentials; confirmation that Huntress MDR is monitoring all endpoints; review of any security events that occurred during the recovery period; and sign-off on the security posture before operations transfer back to Dallas.
4. Kevin D. Nguyen coordinates the transfer of GSL operations back to the Dallas primary ground station after Kowalski and Valencia confirm full readiness. Transfer is executed during a low-traffic period for orbital assets.
5. A full after-action review is conducted within 5 business days of return to normal operations. The review covers: the cause and timeline of the disaster; effectiveness of the BCP activation; gaps identified in recovery procedures; and lessons to be incorporated into the next BCP revision.
6. The BCP is updated based on after-action review findings. All updates are distributed to recovery team members within 10 business days.

Section V: Appendices

Appendix A: ZOS Employee Telephone List

Employee / Title	Contact Information
* Michael R. Torres, Incident Commander	Office: 123-xxx-xxxx Mobile: 123-xxx-xxxx m.torres@zos-secure.com Team Leader
** Daniel J. Kowalski, Ground Systems IT Manager	Office: 123-xxx-xxxx Mobile: 123-xxx-xxxx d.kowalski@zos-secure.com Alt. Team Leader

** Sandra L. Pham, HR and Communications Director	Office: 123-xxx-xxxx Mobile: 123-xxx-xxxx s.pham@zos-secure.com Alt. Team Leader
Rachel M. Okafor, CFO	Office: 123-xxx-xxxx Mobile: 123-xxx-xxxx r.okafor@zos-secure.com
Gregory A. Whitfield, General Counsel	Office: 123-xxx-xxxx Mobile: 123-xxx-xxxx g.whitfield@zos-secure.com
Lisa M. Cabrera, Dallas Ground Station Operations Lead	Office: 123-xxx-xxxx Mobile: 123-xxx-xxxx l.cabrera@zos-secure.com Dallas Site
Kevin D. Nguyen, Austin Relay Hub Operations Lead	Office: 123-xxx-xxxx Mobile: 123-xxx-xxxx k.nguyen@zos-secure.com Austin Site
Marcus L. Webb, IT Support Technician	Office: 123-xxx-xxxx Mobile: 123-xxx-xxxx m.webb@zos-secure.com
Carlos E. Mendoza, Orbital Systems Security Analyst	Office: 123-xxx-xxxx Mobile: 123-xxx-xxxx c.mendoza@zos-secure.com
Angela C. Rivera, HR Coordinator	Office: 123-xxx-xxxx Mobile: 123-xxx-xxxx a.rivera@zos-secure.com
Thomas W. Brandt, Facilities Manager	Office: 123-xxx-xxxx Mobile: 123-xxx-xxxx t.brandt@zos-secure.com
Patricia M. Solis, Payroll and Accounting	Office: 123-xxx-xxxx Mobile: 123-xxx-xxxx p.solis@zos-secure.com
Jennifer T. Walsh, Operations Manager	Office: 123-xxx-xxxx Mobile: 123-xxx-xxxx j.walsh@zos-secure.com
Donna K. Fields, Executive Assistant	Office: 123-xxx-xxxx Mobile: 123-xxx-xxxx d.fields@zos-secure.com
James R. Holloway, Satellite Network Administrator	Office: 123-xxx-xxxx Mobile: 123-xxx-xxxx j.holloway@zos-secure.com

Noe Valencia, PSSE	Office: (214) 555-0147 Mobile: [Mobile] noe.valencia@zos-secure.com
Fire, Police, Emergency	911

* Indicates Team Leader | ** Indicates Alternate Team Leader

Appendix B: ZOS Alternate Site Information

Field	Details
Primary Alternate Site	Austin Relay Hub, ZOS Austin Operations, Austin, Texas
Austin Site Lead	Kevin D. Nguyen, Austin Relay Hub Operations Lead
Austin Site Contact	k.nguyen@zos-secure.com Mobile: 123-xxx-xxxx
Austin GSL Capability	Full Ground-to-Space Link command and control capability
Austin IT Infrastructure	Redundant network stack; Veeam backup restoration capability; full communications systems
RTO for GSL Failover	4 hours from Dallas facility disruption declaration
Secondary Alternate Site	Remote work arrangements for non-mission-critical functions

Appendix C: ZOS Recovery Priorities

Priority / Function	RTO / Description
Priority 1: GSL Command Operations	4 hours / Austin relay hub activation; transfer of orbital asset command authority
Priority 1: Mission Telemetry Processing	4 hours / Restore telemetry data processing capability at Austin
Priority 2: Core IT Infrastructure	24 hours / Domain controllers, core networking, Splunk SIEM, Huntress MDR verification
Priority 2: Client Data Relay Services	24 hours / Confirm defense and commercial client data relay continuity through Austin

Priority 3: Email and Communications	48 hours / Microsoft 365 is cloud-hosted and expected to be continuously available; internal communication systems restored
Priority 3: HR and Payroll Systems	72 hours / Access to ADP or equivalent payroll system; employee emergency support
Priority 4: Legal and Compliance Systems	5 business days / Access to Archer GRC, contract management, regulatory notification capability
Priority 5: Administrative Functions	As feasible / Non-critical administrative systems and facilities

Appendix D: Emergency Operations Center Locations

EOC Option	Location / Conditions
Primary EOC	Austin Relay Hub, ZOS Austin Operations Facility Preferred for any event affecting the Dallas primary facility
Secondary EOC	Virtual EOC using Microsoft Teams, Signal secure messaging, and external conference bridge For events where travel to Austin is not feasible
Tertiary EOC	Designated hotel conference room in the Dallas-Fort Worth metroplex For short-duration local events requiring in-person coordination

Appendix E: Vital Records Inventory

The following ZOS records are classified as vital records and must be recoverable within 24 hours of a disaster declaration. All vital records are backed up daily via Veeam Enterprise Plus to the ZOS offsite backup repository with copies at the Austin relay hub.

- Satellite command and telemetry configuration files
- Client contracts and service level agreements
- ZOS policy and procedure documents (stored in SharePoint Online via Microsoft 365)
- Personnel records and HR data
- Financial records, accounts, and payroll data
- Network device configurations (backed up nightly to Splunk and secure file storage)

- Cryptographic keys and certificates (stored in CyberArk PAM)
- Legal and regulatory compliance documentation (stored in Archer GRC)

Appendix F: ZOS BCP Maintenance Schedule

Activity	Frequency / Responsible Party
BCP Review and Update	Annual minimum; after any significant organizational change; after any BCP activation Noe Valencia (PSSE) with IRT
Recovery Team Contact Information Update	Quarterly Sandra L. Pham
Austin Relay Hub GSL Failover Test	Semi-annual Kevin D. Nguyen with Daniel J. Kowalski
Full BCP Tabletop Exercise	Annual Incident Commander with full Recovery Team
Veeam Backup Restoration Test	Quarterly Daniel J. Kowalski and James R. Holloway
After-Action Review (post-activation)	Within 5 business days of any BCP activation Incident Commander

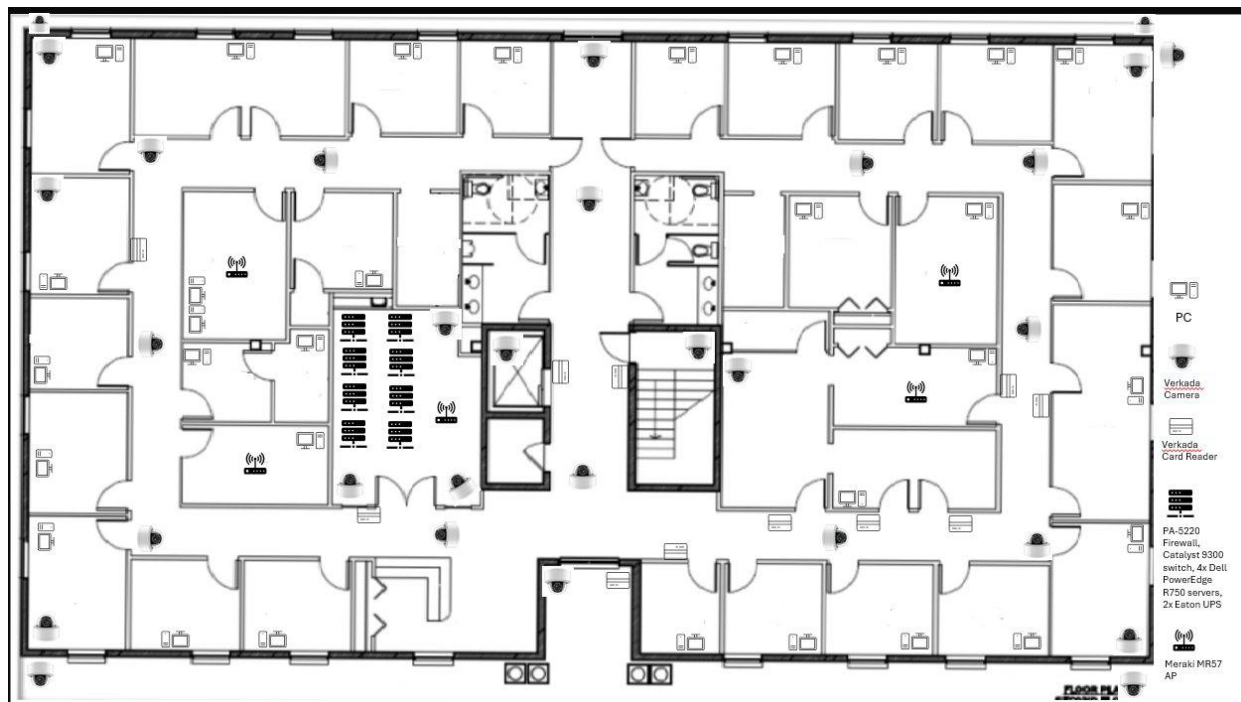
References

- National Institute of Standards and Technology (NIST). Cybersecurity Framework 2.0. February 26, 2024. <https://csrc.nist.gov/pubs/cswp/29>
- NIST. Special Publication 800-207: Zero Trust Architecture. 2020.
- NIST. Special Publication 800-53 Rev. 5: Security and Privacy Controls. 2020.
- NIST. Special Publication 800-40 Rev. 4: Guide to Enterprise Patch Management. 2022.
- CISA. Zero Trust Maturity Model v2.0. April 2023. <https://www.cisa.gov/zero-trust-maturity-model>
- CISA. Cyber Security Evaluation Tool (CSET). <https://www.cisa.gov/resources-tools/services/cyber-security-evaluation-tool>
- CISA. Known Exploited Vulnerabilities (KEV) Catalog. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- MITRE. ATT&CK Enterprise Framework. <https://attack.mitre.org>
- CIS Controls v8. Center for Internet Security. 2021. <https://www.cisecurity.org/controls/v8>
- IBM Security. Cost of a Data Breach Report 2024. 2024.
- Verizon. 2025 Data Breach Investigations Report (DBIR). 2025.
- SANS Institute. Security Policy Templates. <https://www.sans.org/information-security-policy/>
- Palo Alto Networks. PA-5220 Next-Generation Firewall. <https://www.paloaltonetworks.com>
- Cisco Systems. Catalyst 9300 Series Switches. <https://www.cisco.com>
- Cisco Meraki. MR57 Access Point. <https://meraki.cisco.com>
- Huntress. Managed EDR Platform. <https://www.huntress.com>
- Splunk Inc. Splunk Enterprise SIEM. <https://www.splunk.com>
- Okta Inc. Workforce Identity Cloud. <https://www.okta.com>
- CyberArk. Privileged Access Management. <https://www.cyberark.com>
- Zscaler. Zero Trust Exchange. <https://www.zscaler.com>
- Qualys. Vulnerability Management, Detection and Response (VMDR). <https://www.qualys.com>
- KnowBe4. Security Awareness Training. <https://www.knowbe4.com>
- Veeam. Enterprise Plus Backup and Recovery. <https://www.veeam.com>
- Dell Technologies. PowerEdge R750 Server. <https://www.dell.com>

Appendices

Appendix A: Physical Network Diagram with Device Placement

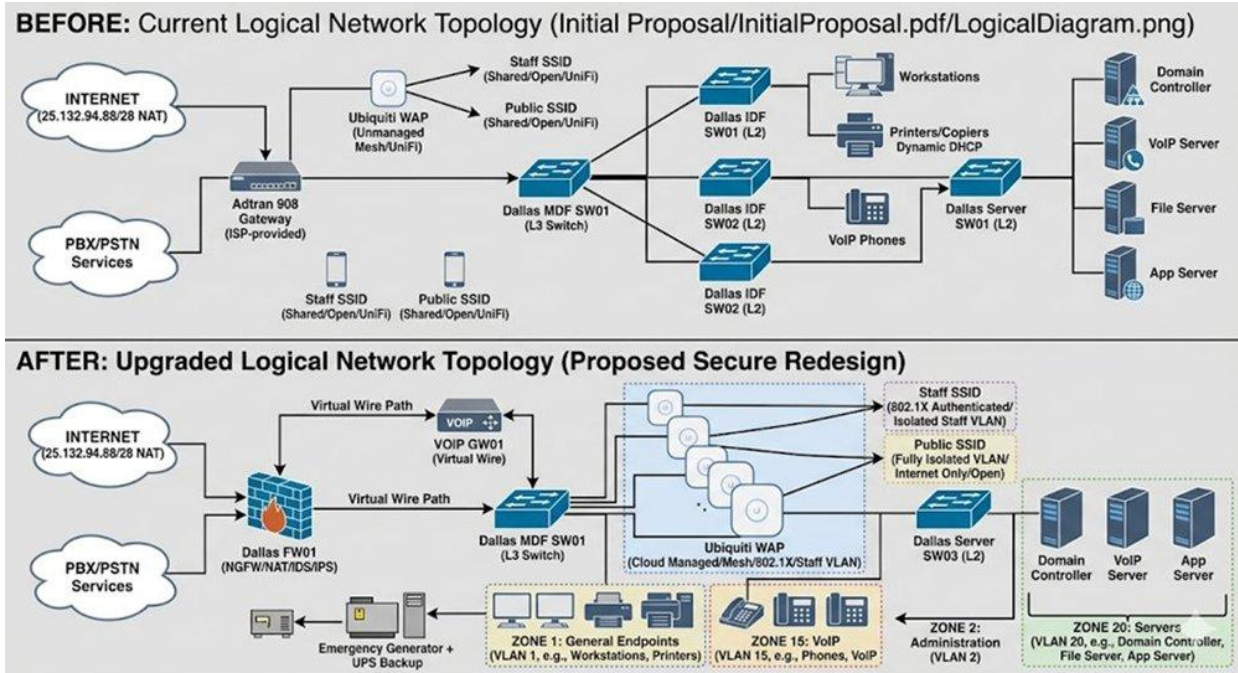
The floor plan below shows the full ZOS Dallas ground station with all network devices, Verkada cameras, card readers, and WAPs placed on the building layout. The MDF room in the center of the building houses the core switching stack, firewall HA pair, Dell PowerEdge R750 servers, and Eaton UPS units. Two IDF distribution points connect to the east and west wings.



Appendix A: ZOS Dallas Physical Network Topology

Appendix B: Before and After Network Topology Comparison

These diagrams show the before and after states of the ZOS Dallas network. The top is the original network that received a Security Assurance Level of Low in the CSET assessment. The bottom is the redesigned ZOS network with every identified gap closed.



Appendix B: ZOS Network Before and After Comparison

DOMAIN	FORECASTING	PLANNING	ORGANIZING	COORDINATING	CONTROLLING
Identity and Access Governance (IAG)	Quarterly identity threat reviews; CISA ZTMM Identity pillar assessment; MFA coverage gap analysis	Annual Identity Security Roadmap; FIDO2 for privileged roles; RBAC matrices with access workflows	IAM Engineer and Privileged Access Admin; PAM tool deployment; SSO and lifecycle platform	HR joiner/mover/leaver integration; under 4 hour deprovisioning SLA; quarterly Identity Review Board	Monthly access certifications; dormant account flagging; 100% MFA target; monthly CISO reporting
Threat Detection and Incident Response (TDIR)	CTI program with CISA KEV and MITRE ATT&CK; annual tabletop; 18-month red/purple team exercises	IRP with P1 through P5 severity levels; ransomware double-extortion playbook; HIPAA and GDPR notification timelines	vSOC with 24/7 MDR partner; pre-constituted IRT with defined roles; out-of-band comms tested quarterly	Integrated with BCM; pre-established FBI IC3, CISA, and legal counsel protocols; SIEM to ITSM ticketing	P1 MTTD under 30 min; P1 MTTR under 4 hours; mandatory PIRs within 5 days; semi-annual IRP exercises
Data Protection and Privacy (DPP)	Annual data discovery and classification; regulatory horizon calendar 180+ days ahead	4-tier classification policy; AES-256 and TLS 1.3 standards; DPIA process;	DPO and embedded data stewards; DLP tooling; vendor security assessment	Legal for BAA and GDPR; Procurement for vendor risk; integrated with TDIR IRP	Monthly DLP exception review; 100% encryption target; annual privacy audits

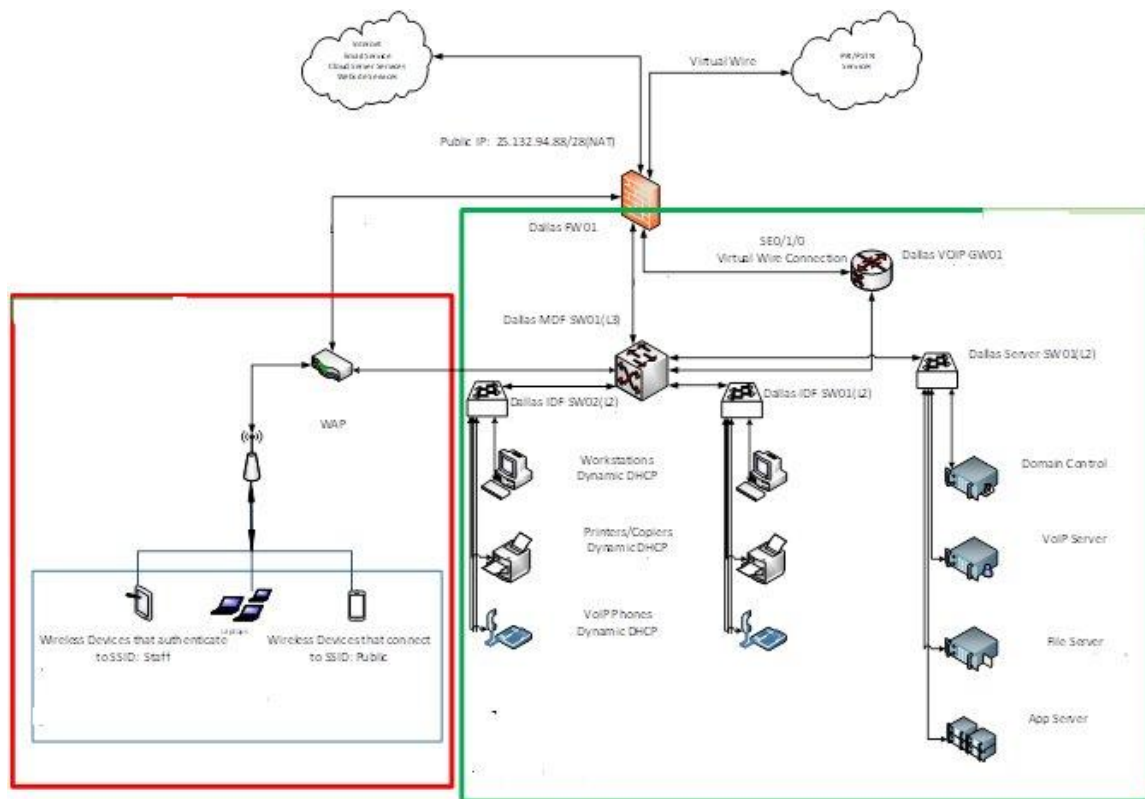
		DPA and BAA schedule	before onboarding		
Vulnerability and Configuration Management (VCM)	CISA KEV catalog monitoring multiple times per week; CMDB cross-referencing; NVD advisory feeds	KEV 48-hour SLA; Critical 15-day SLA; High 30-day SLA; CIS Benchmark baselines	Vulnerability Management Engineer; Qualys VMDR deployment; CMDB maintained	Patch windows coordinated with IT Operations; change advisory board approval for critical patches	Weekly Qualys scan reports; monthly vulnerability trend analysis; annual pen test findings review
Regulatory Compliance and Audit Readiness (RCAR)	Regulatory horizon calendar 180+ days ahead; cyber insurance renewal as forcing function	Annual Compliance Work Plan; continuous controls monitoring via Archer GRC; multi-framework alignment	Compliance and Risk Manager; GRC platform as system of record; external auditor relationships	Finance for budgeting obligations; Procurement for third-party compliance; quarterly board reporting	Annual SOC 2 audit; CMMC Level 2 assessment; internal audit findings tracked to closure in GRC
Security Culture and Workforce Resilience (SCWR)	Annual phishing susceptibility baseline; workforce risk profiling; security culture survey	KnowBe4 quarterly training calendar; biannual IRT tabletop exercise schedule; new hire onboarding	Security Awareness Lead; KnowBe4 platform managed; phishing simulation campaign library	HR integration for new hire onboarding; coordinated with TDIR for exercise scenarios	Monthly phishing click rate tracked; quarterly training completion rate; exercise after-action reports

This table summarizes Fayol's five management functions across all six AZTOF domains. It is the quick-reference governance tool used by the CISO, executive leadership, and auditors to verify that each domain has clear ownership, defined activities, and measurable outcomes.

Appendix C: AZTOF Governance Summary Matrix

Appendix D: Original Logical Topology

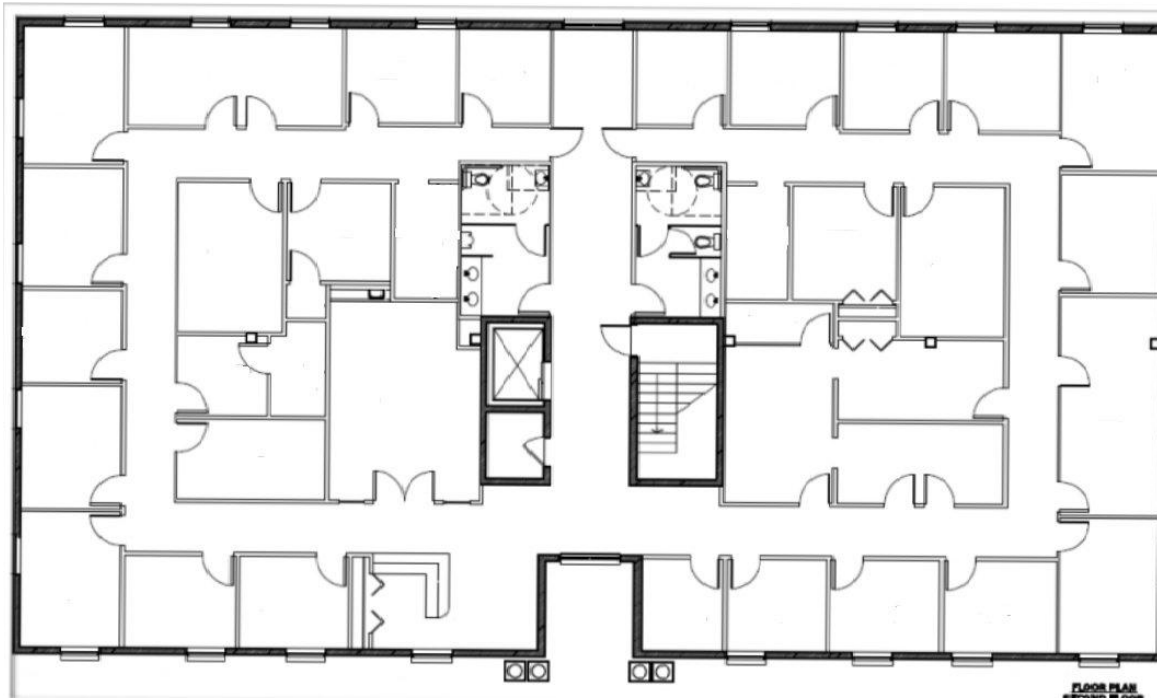
This diagram shows the original ZOS Dallas logical topology before the redesign. It reflects the network assessed by the CSET tool on February 20, 2026.



Appendix D: Original ZOS Dallas Logical Network Topology

Appendix E: Clean Building Floor Plan

This is the base floor plan for the ZOS Dallas ground station facility without device overlays.



Appendix E: ZOS Dallas Ground Station Floor Plan

Appendix F: IRT Member Contact List

The IRT member contact list includes primary and secondary contact information for all Incident Response Team members. It is maintained in both digital and printed form. The printed copy is stored in the biometric safe in the MDF room to ensure availability if digital systems are down during a severe incident. Contact details are maintained as a controlled document and are not reproduced here for security reasons.

Appendix G: BCP Employee Telephone List

The BCP employee telephone list includes office, home, and mobile contact information for all BCP recovery team members organized by role, with team leader and alternate team leader designations. All ZOS personnel are instructed to proceed to the Austin relay hub if they cannot make direct contact with management during a declared disaster, consistent with Phase II activation procedures. Maintained as a controlled document per BCP Appendix A.